
Mariana BS - Cybersecurity Engineer
GUIA COMPLETO DE ESTUDOS
Analista SOC N1
ARQUITETURA TAMBÉM É SEGURANÇA
Usuários
Switch
Rede Interna
Servidores
AD
DNS
VLANs
Internet
Firewall
DMZ
Proxy
WAF
Load Balancer
E-mail
VPN
Nuvem
aws
Aplicações em nuvem
Monitoramento e Detecção
IDS
EDR
SIEM
Segmentação
Zonas
VLANs
Regras
Fluxos
SOC N1
SEM LOG NÃO HÁ HISTÓRIA
Fluxo e Pontos de Log
Cliente
Proxy
Firewall
Servidor
Logs de equipo/endpoint
• EDR
• Sistema
• Aplicações
Logs de proxy
• Acesso
• URL
• Usuário
• Categoria
Logs de firewall
• Conexões
• Regras
• Bloqueios
• NAT
Logs de servidor
• Aplicação
• Sistema
• Autenticação
• Serviços
Pipeline de Telemetria
Fontes de log
Coleta
Normalização
SIEM
Matriz de Visibilidade
Componente | Logs | Quem enxerga | Quem bloqueia | Quem detecta
Firewall | Sim | SOC / Net | Sim | Sim
Proxy | Sim | SOC | Sim | Sim
EDR | Sim | SOC | Sim | Sim
Servidor | Sim | TI / SOC | Não | Sim
Nuvem | Sim | SOC / Cloud | Sim | Sim
ZONAS E SEGMENTAÇÃO
FIREWALL E DMZ
VLANs
AD, DNS E PROXY
VPN, WAF E LOAD BALANCER
MAIL E SERVIDORES
IDS, EDR E SIEM
ARQUITETURA EM NUVEM
ARQUITETURA HOJE ALERTA MENOS AMANHÃ
THREAT HUNTING
Plano de Estudo
Entender a arquitetura
Identificar os logs
Mapear os fluxos
Encontrar os pontos de visibilidade
Praticar com a Empresa Alfa
Montar meu laboratório
REDE BEM FEITA DÁ MENOS TRABALHO
Módulo 2 — Arquitetura de Ambientes Corporativos
Onde estão os logs, quem enxerga, quem bloqueia, quem detecta
Neste volume:
• Zonas e segmentação
• Componentes de uma rede corporativa (firewall, DMZ, VLANs, servidores, AD, DNS, proxy, VPN, WAF, load balancer, e-mail, IDS, EDR, SIEM, nuvem)
• Fluxos com pontos de log
• Pipeline de telemetria
• Matriz de visibilidade
• Método para ler qualquer arquitetura
Prática:
A arquitetura da Empresa Alfa (cheia de problemas, como manda a tradição) e o planejamento do seu laboratório.
EMPRESA ALFA
Pré-requisitos:
Módulos 0 e 1.

Sumário

Módulo 2: Arquitetura de Ambientes Corporativos 4
2.1 Objetivo 4
2.2 Por que arquitetura importa para um N1 4
As quatro perguntas 4
2.3 Visão geral: a arquitetura de referência 5
2.4 Zonas de confiança e segmentação 7
Matriz de fluxos permitidos 7
Tiering de administração (visão rápida) 8
Zero Trust em uma frase 8
2.5 Os componentes, um a um 8
2.5.1 Internet e roteador de borda 8
2.5.2 Firewall de borda (NGFW) 9
2.5.3 DMZ 10
2.5.4 LAN e VLANs 11
2.5.5 Servidores: arquivos, aplicação e banco de dados 11
2.5.6 Active Directory e controladores de domínio 12
2.5.7 DNS e DHCP internos 13
2.5.8 Proxy web / Secure Web Gateway 14
2.5.9 VPN e ZTNA 15
2.5.10 WAF (Web Application Firewall) 15
2.5.11 Load balancer 16
2.5.12 Gateway de e-mail 18
2.5.13 IDS, IPS e NDR 18
2.5.14 EDR 19
2.5.15 SIEM 20
2.5.16 Nuvem e SaaS 20
2.5.17 Gerência: jump servers, backup e monitoramento 22
2.6 Fluxos típicos e onde cada um é registrado 22
Publicação de aplicação: Internet → Firewall → DMZ → WAF → Aplicação → Banco 22
Saída do usuário: Usuário → Switch → Firewall → Internet 23
Identidade: o login que acontece em dois lugares 24
Trabalho remoto: o perímetro foi para casa 25
2.7 Como os logs chegam ao SOC 25
Ingestão, parsing e normalização (o básico) 26
Consultas rápidas de saúde (amostra; aprofundado nos Módulos 6 e 16) 27
2.8 Matriz de visibilidade 27
2.9 Lendo qualquer arquitetura em cinco passos 28
2.10 Como isso aparece no SOC: três mini-casos 29

Caso 1: "SQL Injection detectado no WAF" 29
Caso 2: "Host 10.50.0.30 atacando o portal" 30
Caso 3: "Servidor sem EDR com comportamento estranho" 30
2.11 Comandos: descobrindo a arquitetura a partir de um host 30
Windows 30
Linux 31
2.12 Ferramentas 31
Fechamento do Módulo 2 32
Erros comuns 32
Falsos positivos comuns ligados à arquitetura 32
Exercícios 33
Laboratório 34
Perguntas de entrevista 35
Checklist de domínio 37
Resumo do módulo 38
Respostas comentadas dos exercícios 38
Próximo módulo 40

Se o sumário aparecer vazio, clique com o botão direito sobre ele no Word e escolha "Atualizar campo".

Módulo 2: Arquitetura de Ambientes Corporativos

2.1 Objetivo

No Módulo 1 você aprendeu como um pacote anda. Agora vamos olhar o mapa da cidade inteira: quais prédios existem, quais ruas ligam um ao outro, onde ficam os pedágios e onde estão as câmeras. Ao final deste módulo você deve conseguir:

- Desenhar e explicar a arquitetura típica de uma empresa: Internet, borda, DMZ, LAN, VLANs, zonas de servidores, gerência e convidados.
- Explicar o que é, por que existe e que logs gera cada componente: roteador, firewall, DMZ, servidores, Active Directory, DNS, DHCP, proxy, VPN, WAF, load balancer, gateway de e-mail, IDS/IPS, EDR, SIEM e serviços de nuvem.
- Seguir um fluxo (publicação de aplicação, navegação do usuário, login, acesso remoto) e dizer em que pontos ele é registrado.
- Entender como o log sai da fonte e chega ao SIEM, e onde ele costuma se perder.
- Olhar para qualquer arquitetura e responder às quatro perguntas do SOC: **onde estão os logs, quem enxerga essa comunicação, qual equipamento pode bloquear e qual ferramenta pode detectar**.
- Identificar pontos cegos e registrá-los como lacuna de visibilidade, em vez de concluir que "nada aconteceu".

2.2 Por que arquitetura importa para um N1

Um alerta nunca chega sozinho. Ele chega de **algum lugar** da rede, gerado por **algum sensor**, sobre uma comunicação que passou (ou não passou) por **alguns equipamentos**. Se você não conhece esse caminho, não sabe onde procurar a próxima evidência, não sabe quem pode bloquear e não percebe quando falta um pedaço da história.

Na prática, entender a arquitetura responde a perguntas que aparecem o tempo todo na fila:

- "O WAF alertou SQL Injection. O ataque chegou na aplicação?" Você precisa saber o que vem depois do WAF.
- "O IP atacante é 10.50.0.30." É um host interno comprometido ou o load balancer repassando a requisição de alguém de fora?
- "O EDR detectou malware no notebook. Ele falou com alguém?" Você precisa saber se esse notebook passa pelo proxy, pelo firewall ou por nenhum dos dois.
- "O servidor foi acessado por RDP." De onde? Da VPN, de um jump server, de outra estação? Quem registra cada um desses caminhos?

As quatro perguntas

Pergunta	O que você está procurando	Exemplo
Onde estão os logs?	Quais equipamentos e sistemas registram essa comunicação ou ação, e se esses logs chegam ao SIEM.	O acesso à aplicação aparece no firewall, no WAF, no load balancer e no servidor web.

Pergunta	O que você está procurando	Exemplo
Quem enxerga essa comunicação?	Por quais pontos o tráfego passa obrigatoriamente (pontos de passagem) e em qual camada cada um enxerga.	O firewall vê IP e porta; o WAF vê a URL e o parâmetro; o EDR vê o processo.
Qual equipamento pode bloquear?	Quem tem capacidade e autorização para impedir, e qual o impacto de bloquear ali.	Bloquear no WAF afeta uma aplicação; bloquear no firewall de borda pode afetar a empresa inteira.
Qual ferramenta pode detectar?	Onde existe lógica de detecção (regras, assinaturas, comportamento) para esse tipo de atividade.	Exfiltração por DNS: o resolver vê, mas só detecta se alguém criou a regra.

O QUE UM N1 REALMENTE PRECISA SABER

Arquitetura, para o N1, não é saber configurar equipamento. É saber:

- **onde** o tráfego passa e **onde** ele não passa;
- **que log** cada ponto gera e **se esse log chega** ao SIEM;
- **quem é dono** de cada componente e **quem pode agir** nele;
- **o que é crítico** (controlador de domínio, banco de dados, backup) e o que pode esperar.

Ninguém vai te pedir para configurar um load balancer. Vão te pedir para não chamar o load balancer de atacante.

NA VIDA REAL

O diagrama oficial de rede foi feito para a auditoria de 2021.

Desde então: duas filiais novas, uma migração para a nuvem pela metade, um firewall trocado e uma VLAN "temporária" criada numa sexta-feira.

O diagrama, por sua vez, continua lindo.

Use o diagrama como ponto de partida, nunca como prova. A rede real é a que aparece nos logs.

2.3 Visão geral: a arquitetura de referência

Toda empresa é diferente, mas a maioria segue um desenho parecido com o da figura abaixo. Use-o como **mapa mental padrão**: quando entrar num SOC ou atender um cliente novo, compare o ambiente real com ele e anote as diferenças. As diferenças costumam ser exatamente onde moram os problemas.

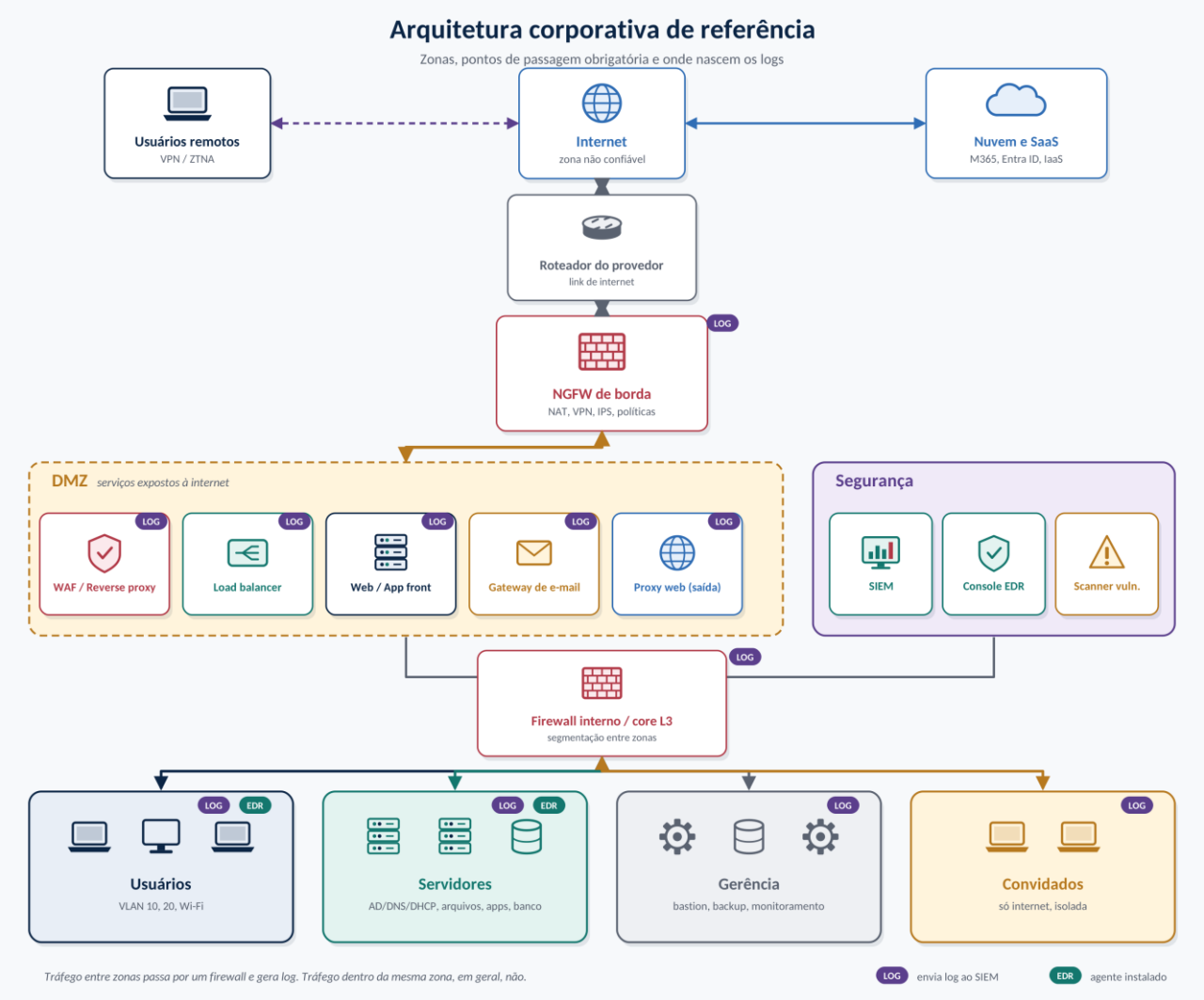


Figura 2.1: Arquitetura corporativa de referência com zonas, pontos de passagem e fontes de log

Lendo a figura de cima para baixo:

1. **Internet:** tudo que está fora da empresa. Zona não confiável. Daqui vêm clientes legítimos, parceiros, usuários remotos e atacantes, todos com a mesma cara de "IP público".
2. **Roteador do provedor:** entrega o link de internet. Normalmente administrado pela operadora; raramente envia log ao SOC.
3. **NGFW de borda:** o principal ponto de passagem obrigatória entre a empresa e a internet. Faz NAT, filtra, frequentemente termina a VPN e roda IPS. Gera um dos logs mais usados pelo SOC.
4. **DMZ:** zona intermediária para o que precisa ser acessado da internet (sites, e-mail, proxy reverso). Se um servidor da DMZ for comprometido, o atacante ainda não está na rede interna.
5. **Firewall interno:** separa as zonas internas entre si (usuários, servidores, gerência, convidados). Em muitas empresas é o mesmo equipamento da borda com mais interfaces; em outras, é um switch L3 com ACLs.
6. **Zonas internas:** usuários, servidores, gerência e convidados, cada uma com regras diferentes sobre quem pode falar com quem.
7. **Segurança:** SIEM, console do EDR e scanner de vulnerabilidades. Também são ativos críticos: quem controla o EDR controla todos os endpoints.

8. **Nuvem e SaaS:** e-mail, arquivos, identidade e aplicações que não estão mais dentro do prédio. Têm seus próprios logs, que precisam ser integrados ao SIEM.

2.4 Zonas de confiança e segmentação

Uma **zona** é um grupo de sistemas com o mesmo nível de confiança e as mesmas regras de acesso. A **fronteira** entre duas zonas é onde existe controle (firewall, ACL) e, portanto, onde existe log. **Segmentação** é a prática de dividir a rede em zonas para limitar o que um sistema comprometido consegue alcançar.

Zona	O que contém	Nível de confiança	Regra geral
Internet	Tudo fora da empresa.	Nenhuma.	Só entra o que foi explicitamente publicado.
DMZ	Serviços expostos: site, WAF, gateway de e-mail, proxy reverso, às vezes VPN.	Baixa: exposta e mais atacada.	Internet entra só nas portas publicadas; DMZ fala com o mínimo da rede interna.
Usuários	Estações e notebooks, por andar, departamento ou Wi-Fi.	Média: usuários clicam em coisas.	Saem para a internet pelo proxy; acessam servidores necessários; não acessam gerência.
Servidores	AD, DNS, DHCP, arquivos, aplicações, bancos de dados.	Alta.	Recebem conexões dos usuários só nas portas dos serviços; administração só a partir da gerência.
Gerência	Jump servers (bastion), monitoramento, backup, consoles de administração.	Muito alta: daqui se administra tudo.	Acesso restrito a administradores, com MFA e registro.
Convidados	Wi-Fi de visitantes e dispositivos pessoais.	Nenhuma.	Só internet; nunca alcança a rede interna.
OT / IoT	Câmeras, controle de acesso, automação predial, chão de fábrica.	Baixa e frágil.	Isolada; equipamentos antigos que não recebem atualização nem agente.

Matriz de fluxos permitidos

Uma forma simples de documentar segmentação é uma matriz de "quem pode iniciar conexão para quem". Ela vira o seu gabarito: qualquer log mostrando um fluxo marcado como **não** é, no mínimo, uma pergunta a fazer.

Origem ↓ / Destino →	Internet	DMZ	Usuários	Servidores	Gerência
Internet	n/a	Só portas publicadas	Não	Não	Não
DMZ	Restrito (atualizações)	Restrito	Não	Só o necessário (ex.: app → banco)	Não
Usuários	Via proxy	Sim (como cliente)	Não (entre estações)	Portas de serviço	Não
Servidores	Restrito	Restrito	Restrito	Conforme aplicação	Não

Origem ↓ / Destino →	Internet	DMZ	Usuários	Servidores	Gerência
Gerência	Restrito	Administração	Administração	Administração	Sim

> **O QUE UM N1 REALMENTE PRECISA SABER**
>
> Repare na célula **Usuários → Usuários: não**. Estações normalmente não têm motivo para falar entre si por SMB, RDP ou WinRM. Quando uma estação começa a se conectar em dezenas de outras na porta 445, isso tem cara de movimento lateral ou de worm.
>
> Só que, em muitas redes, esse tráfego fica dentro da mesma VLAN e **não passa por firewall nenhum**. Quem vê? O EDR das duas pontas e, se existir, um sensor de rede interno. Guarde isso para os Módulos 7 e 14.

Tiering de administração (visão rápida)

Muitas empresas organizam os ativos em **camadas de privilégio** (tiers). A ideia é que uma credencial de um nível nunca seja usada num nível menos protegido, para não ser roubada ali:

Tier	O que contém	Por que o N1 se importa
Tier 0	Controladores de domínio, Entra Connect, PKI, contas de Domain Admin, ferramentas que controlam a identidade.	Qualquer alerta envolvendo Tier 0 tem prioridade alta. Comprometer Tier 0 é comprometer tudo.
Tier 1	Servidores e aplicações de negócio.	Onde estão os dados. Alvo de ransomware e exfiltração.
Tier 2	Estações de trabalho e dispositivos de usuário.	Onde a maioria dos ataques começa (phishing, download).

Um administrador fazendo login com conta de Domain Admin numa estação comum (Tier 2) é, mesmo sem malware nenhum, um risco que merece registro. Se essa estação estiver comprometida, a credencial mais poderosa da empresa pode estar na memória dela.

Zero Trust em uma frase

Zero Trust é o princípio de não confiar em nada só porque está "dentro" da rede: cada acesso é verificado pela identidade, pelo estado do dispositivo e pelo contexto, a cada vez. Na prática, isso se traduz em MFA, acesso condicional, ZTNA no lugar de VPN de rede inteira e microssegmentação. Para o SOC, significa mais logs de **identidade** e menos dependência do perímetro.

2.5 Os componentes, um a um

Para cada componente, a ficha abaixo responde às mesmas perguntas: o que é, como funciona, por que existe, onde aparece, como você vê no SOC, que logs mostram, o que procurar, o que pode ser benigno ou suspeito, próximo passo e quando escalar.

2.5.1 Internet e roteador de borda

Pergunta	Resposta
O que é?	O link com o provedor (ISP) e o roteador que conecta a empresa à internet. Às vezes há dois links de operadoras diferentes para redundância.
Como funciona?	O roteador recebe o bloco de IPs públicos da empresa e encaminha o tráfego entre o provedor e o firewall de borda. Pode usar BGP quando a empresa tem IPs próprios.
Por que existe?	Sem ele não há internet. A redundância evita que a queda de uma operadora pare a empresa.
Onde aparece?	No topo de qualquer diagrama, antes do firewall. Muitas vezes é da operadora e fica fora do controle da TI.
Como vejo no SOC?	Raramente gera alerta. Aparece em incidentes de disponibilidade (link caiu, ataque de negação de serviço) e quando você precisa saber **quais IPs públicos pertencem à empresa**.
Que logs mostram isso?	Logs do roteador (quando existem), NetFlow, painel da operadora, serviço anti-DDoS.
O que procuro?	Saturação de link, picos de tráfego de entrada, mudanças de rota.
O que pode ser benigno?	Picos em horário de atualização, backup para nuvem, reunião geral transmitida.
O que pode ser suspeito?	Volume massivo de entrada vindo de muitas origens (DDoS); saída massiva sem explicação.
Próximo passo	Confirmar com NOC/rede; correlacionar com o firewall para saber qual host ou serviço está envolvido.
Quando escalo?	Indisponibilidade de serviço crítico ou suspeita de DDoS, conforme procedimento (normalmente envolve NOC, operadora e gestão).

> **DICA**
>
> Pergunta para fazer na primeira semana: **quais são os IPs públicos da empresa?** Anote num lugar fácil.
>
> Metade dos alertas de "IP interno atacando a internet" e de "acesso do exterior" se resolve em segundos quando você sabe, de cabeça, que 198.51.100.0/28 é a própria empresa.

2.5.2 Firewall de borda (NGFW)

Pergunta	Resposta
O que é?	O equipamento que controla tudo que entra e sai da empresa. Nos ambientes modernos é um **NGFW**: além de IP e porta, identifica aplicação e usuário, faz inspeção TLS, IPS, filtro de URL e, muitas vezes, termina a VPN.
Como funciona?	Avalia cada nova sessão contra uma lista ordenada de regras, faz NAT de saída (PAT) e de entrada (DNAT para serviços publicados) e mantém a tabela de sessões (stateful). Detalhes no Módulo 1, seção 1.15.
Por que existe?	Para que só o tráfego autorizado atravesse o perímetro e para que exista registro de tudo que atravessou.
Onde aparece?	Entre o roteador do provedor e a rede interna/DMZ. Frequentemente em par (alta disponibilidade).
Como vejo no SOC?	É uma das fontes mais consultadas: quem falou com quem, por qual porta, quanto trafegou, qual regra permitiu. Também gera alertas próprios de IPS e de reputação.

Pergunta	Resposta
Que logs mostram isso?	Tráfego (sessão, NAT, bytes, regra), ameaças (IPS, antivírus de rede), URL, VPN, administração do próprio firewall.
O que procuro?	Allows inesperados (entrada em serviço sensível, saída para destino raro), volumes assimétricos, regras amplas casando tráfego estranho, mudanças de configuração no próprio firewall.
O que pode ser benigno?	Denies de varredura da internet (constantes), atualização de software, backup em nuvem, scanner autorizado.
O que pode ser suspeito?	RDP/SMB/SSH aceitos vindos da internet; estação enviando gigabytes para fora; conexões periódicas ao mesmo destino desconhecido; regra alterada fora de janela de mudança.
Próximo passo	Identificar o ativo interno (NAT, DHCP, CMDB), o processo (EDR), enriquecer o destino e verificar a regra que permitiu.
Quando escalo?	Comunicação confirmada com destino malicioso, exposição de serviço crítico com tentativas ativas, alteração não autorizada de regras.

2.5.3 DMZ

Pergunta	Resposta
O que é?	Do inglês "demilitarized zone": uma rede intermediária onde ficam os serviços que precisam ser acessados da internet.
Como funciona?	Pode ser feita com um firewall de três pernas (internet, DMZ, rede interna) ou com dois firewalls em sequência (back-to-back), de fabricantes diferentes em ambientes mais exigentes. A internet só alcança a DMZ nas portas publicadas; a DMZ só alcança o mínimo necessário da rede interna.
Por que existe?	Serviços expostos são os mais atacados. Se um deles for comprometido, a DMZ impede que o atacante caia direto na rede interna.
Onde aparece?	Entre a borda e a rede interna. Contém WAF, reverse proxy, servidores web, gateway de e-mail, às vezes servidores de VPN, DNS externo e proxy de saída.
Como vejo no SOC?	Como origem de alertas de ataque web e como **ponto de partida de movimento lateral** se algo exposto for comprometido.
Que logs mostram isso?	Firewall entre internet e DMZ, firewall entre DMZ e rede interna, WAF, servidores web, EDR nos servidores da DMZ.
O que procuro?	Servidor da DMZ iniciando conexões para a rede interna fora do padrão; servidor da DMZ iniciando conexões para a internet (download de ferramentas, C2); processos estranhos no servidor web.
O que pode ser benigno?	Aplicação na DMZ consultando o banco interno na porta definida; atualizações de sistema para repositórios conhecidos.
O que pode ser suspeito?	Servidor web abrindo SMB (445) ou RDP (3389) para servidores internos; servidor web baixando arquivos de IP desconhecido; processo de shell filho do serviço web (`w3wp.exe` gerando `cmd.exe`).
Próximo passo	Verificar no EDR do servidor da DMZ o processo responsável; comparar com a matriz de fluxos permitidos; verificar logs do WAF e do servidor web anteriores ao evento.
Quando escalo?	Qualquer indício de que um servidor exposto executou comandos ou tentou alcançar a rede interna fora do padrão.

> **NA VIDA REAL**
>
> Arquiteto: "Temos DMZ."
>
> Analista, olhando a regra: "DMZ → LAN: ANY → ANY → ALLOW."
>
> Arquiteto: "Mas temos DMZ."
>
> DMZ com permissão total para a rede interna é só uma VLAN com nome bonito. Quando a matriz de fluxos e as regras reais discordam, as regras reais vencem.

2.5.4 LAN e VLANs

Pergunta	Resposta
O que é?	A rede local onde ficam usuários e servidores, dividida logicamente em VLANs (Módulo 1, seção 1.6).
Como funciona?	Switches de acesso conectam os dispositivos em portas access de cada VLAN; trunks 802.1Q levam as VLANs até o switch core ou firewall, que roteia (e filtra) entre elas.
Por que existe?	Separar grupos com necessidades e riscos diferentes, reduzir broadcast e limitar o alcance de um comprometimento.
Onde aparece?	Em cada andar, filial e data center. A VLAN de um ativo costuma estar na CMDB, no IPAM ou no próprio nome da sub-rede.
Como vejo no SOC?	A VLAN diz **se o tráfego passou por um firewall** (entre VLANs) ou **ficou no switch** (mesma VLAN). Também diz se um dispositivo está onde deveria.
Que logs mostram isso?	Switch (porta, MAC, port security), NAC (802.1X), DHCP por escopo, firewall interno entre VLANs.
O que procuro?	Dispositivos em VLAN errada, MAC desconhecido em área sensível, tráfego entre VLANs que a matriz proíbe.
O que pode ser benigno?	Notebook mudando de VLAN entre cabo e Wi-Fi; equipamento novo ainda não cadastrado.
O que pode ser suspeito?	Estação na VLAN de servidores ou de gerência; dispositivo que não pertence à empresa conectado em porta de cabo; estação varrendo a própria VLAN.
Próximo passo	Identificar porta física, MAC e fabricante; consultar NAC/CMDB; confirmar com o time de redes.
Quando escalo?	Dispositivo não autorizado em segmento sensível ou atividade de varredura/MitM na LAN (como no PCAP do Módulo 1).

2.5.5 Servidores: arquivos, aplicação e banco de dados

Pergunta	Resposta
O que é?	Os sistemas que entregam serviços e guardam dados: servidores de arquivos (compartilhamentos SMB), servidores de aplicação (ERP, intranet, APIs) e bancos de dados (SQL Server, Oracle, PostgreSQL, MySQL).
Como funciona?	Ficam na zona de servidores ou no data center/nuvem; usuários e outras aplicações se conectam a eles nas portas dos serviços; administradores acessam por RDP, SSH ou WinRM, idealmente a partir de jump servers.

Pergunta	Resposta
Por que existe?	É onde mora o negócio: dados de clientes, financeiro, RH, propriedade intelectual.
Onde aparece?	Zona de servidores, DMZ (front-ends) e nuvem (IaaS).
Como vejo no SOC?	São os ativos de maior **criticidade** depois da identidade. Alertas neles sobem de prioridade. Também são alvo clássico de ransomware (criptografia de compartilhamentos) e exfiltração.
Que logs mostram isso?	Windows Security (4624, 4625, 5140, 5145 para compartilhamentos), System (7045 serviço criado), logs da aplicação, auditoria do banco, EDR, logs do servidor web.
O que procuro?	Logons de origens incomuns, administração fora do jump server, acesso em massa a arquivos, renomeação massiva, consultas volumosas ao banco, novos serviços e tarefas agendadas.
O que pode ser benigno?	Backup lendo todos os arquivos à noite; antivírus varrendo; deploy de aplicação em janela aprovada; conta de serviço da aplicação consultando o banco.
O que pode ser suspeito?	Estação de usuário acessando `ADMIN$` ou `C$` do servidor; centenas de arquivos renomeados por minuto; conta de usuário comum fazendo RDP no servidor de banco; exportação incomum de tabelas.
Próximo passo	Identificar origem (host, usuário, processo), comparar com o padrão da conta e do servidor, verificar se o servidor tem EDR e se o log está chegando.
Quando escalo?	Indícios de ransomware (criptografia ou renomeação em massa), acesso administrativo não explicado, exfiltração de dados sensíveis.

2.5.6 Active Directory e controladores de domínio

Pergunta	Resposta
O que é?	O **Active Directory Domain Services (AD DS)** é o diretório que guarda usuários, computadores, grupos e políticas de uma rede Windows. Os **controladores de domínio (DCs)** são os servidores que hospedam o AD e autenticam todo mundo.
Como funciona?	Estações e servidores ingressados no domínio autenticam contra os DCs usando **Kerberos** (e NTLM como legado); aplicações consultam o AD via **LDAP**; políticas são distribuídas por **GPO**. Os DCs replicam entre si. Detalhes no Módulo 8.
Por que existe?	Centralizar identidade e permissões: um usuário, uma senha, acesso controlado a centenas de sistemas.
Onde aparece?	Zona de servidores (às vezes com zona própria). São **Tier 0**: o ativo mais crítico da rede.
Como vejo no SOC?	Quase todo incidente sério passa pelo AD: roubo de credencial, escalonamento de privilégio, criação de contas, adição a grupos administrativos, movimento lateral.
Que logs mostram isso?	Security dos DCs: 4624/4625 (logon), 4740 (bloqueio), 4768/4769/4771 (Kerberos), 4776 (NTLM), 4720 (conta criada), 4728/4732/4756 (adição a grupo), 4662 (acesso a objeto, quando auditado). Ferramentas de identidade (ex.: Defender for Identity).
O que procuro?	Picos de falhas de autenticação, contas novas ou adicionadas a grupos privilegiados, pedidos anormais de tickets Kerberos, logons de contas administrativas em estações comuns.
O que pode ser benigno?	Admissões e desligamentos com chamado; senha expirada gerando falhas; replicação entre DCs; conta de sincronização (Entra Connect) fazendo muitas leituras.

Pergunta	Resposta
O que pode ser suspeito?	Conta adicionada ao grupo Domain Admins sem mudança aprovada; falhas para muitas contas a partir de um único host (spraying); conta de serviço logando interativamente; replicação de diretório pedida por algo que não é DC (indício de DCSync).
Próximo passo	Identificar quem fez a alteração (conta, host de origem), verificar chamado/mudança, verificar o host de origem no EDR.
Quando escalo?	Qualquer alteração não explicada em grupos privilegiados, sinais de ataque a Kerberos ou indício de comprometimento de DC. **Nunca** isole ou reinicie um DC por conta própria: isso pode parar a empresa.

MOMENTO SOC

Alerta: "Usuário adicionado ao grupo Domain Admins."

Você: verifica o evento 4728. Quem adicionou: `svc_backup`. Host de origem: uma estação do financeiro.

Isso não é uma mudança de rotina. Isso é uma conta de serviço sendo usada fora do seu lugar para dar a alguém a chave da empresa.

Escalonamento imediato, com o evento, o host de origem e a pergunta "existe mudança aprovada?" já respondida.

2.5.7 DNS e DHCP internos

Pergunta	Resposta
O que é?	Serviços de resolução de nomes (DNS) e de entrega de endereços (DHCP) para a rede interna. Em ambientes Windows, o DNS costuma rodar nos próprios DCs; o DHCP pode estar nos DCs ou em servidores dedicados.
Como funciona?	Estações recebem IP, gateway e servidores DNS via DHCP; consultam o DNS interno, que resolve nomes internos (zona do AD) e encaminha o resto para a internet. Detalhes no Módulo 1, seções 1.9 e 1.10.
Por que existe?	Sem DNS, nada funciona (inclusive o AD, que depende de registros SRV). Sem DHCP, cada IP teria que ser configurado à mão.
Onde aparece?	Zona de servidores; às vezes com resolvers ou filtros DNS dedicados (proteção DNS, sinkhole).
Como vejo no SOC?	O DNS mostra **o que** cada host tentou alcançar pelo nome; o DHCP mostra **quem era quem** em cada horário. Juntos, ligam IP a host e host a destino.
Que logs mostram isso?	Log de consultas DNS (precisa estar habilitado; em Windows é o log analítico/debug ou um sensor), Sysmon 22 nas estações, log de concessões DHCP.
O que procuro?	Domínios recém-criados ou maliciosos, NXDOMAIN em massa, consultas TXT anormais, estações usando DNS externo, servidores DHCP não autorizados.
O que pode ser benigno?	Telemetria de software, CDNs, verificação de reputação feita por antivírus.
O que pode ser suspeito?	Ver Módulo 1: DGA, tunneling, fast flux; DHCP entregando DNS externo; consulta a domínio de C2 conhecido.

Pergunta	Resposta
Próximo passo	Identificar host e processo, confirmar se houve conexão, verificar outros hosts com a mesma consulta.
Quando escalo?	Resolução de domínio malicioso seguida de conexão; padrão de DGA ou tunneling; rogue DHCP.

> **NA VIDA REAL**
>
> No curso: "O DNS registra as consultas."
>
> Na vida real: o log de consultas do DNS do Windows estava desativado "porque enchia o disco".
>
> Antes de procurar uma consulta, confirme se ela teria sido registrada. Ausência de log não é ausência de evento.

2.5.8 Proxy web / Secure Web Gateway

Pergunta	Resposta
O que é?	Intermediário pelo qual os usuários acessam a internet. Pode ser um equipamento local ou um serviço em nuvem (**SWG**, Secure Web Gateway). Detalhes no Módulo 1, seção 1.16.
Como funciona?	O navegador é configurado (PAC, GPO ou agente) para enviar as requisições ao proxy, que autentica o usuário, avalia a URL (categoria, reputação), opcionalmente inspeciona o TLS e só então busca o conteúdo.
Por que existe?	Controlar e registrar a navegação por **usuário**, bloquear categorias e sites maliciosos, inspecionar downloads.
Onde aparece?	Na DMZ ou na nuvem; no caminho de saída entre usuários e firewall.
Como vejo no SOC?	Uma das melhores fontes para investigar phishing, download de malware e C2 por HTTP(S), porque traz **usuário + URL** na mesma linha.
Que logs mostram isso?	URL, usuário, IP, categoria, ação, status, user-agent, bytes, tipo de conteúdo.
O que procuro?	Downloads de executáveis e scripts, domínios recém-registrados, user-agents de ferramentas (PowerShell, certutil, curl), uploads grandes, bloqueios repetidos para o mesmo destino.
O que pode ser benigno?	Atualizadores, ferramentas de TI conhecidas, bloqueios de categoria de entretenimento.
O que pode ser suspeito?	Script baixado logo após clique em e-mail; acesso periódico (beaconing) a domínio sem categoria; envio de grandes volumes para armazenamento pessoal.
Próximo passo	Montar timeline e-mail → clique → download → execução, cruzando proxy e EDR.
Quando escalo?	Download seguido de execução, comunicação confirmada com destino malicioso, vários usuários afetados.

> **DICA**
>
> Toda empresa tem uma **lista de exceções** do proxy: sites que não passam pela inspeção TLS (bancos, saúde, governo) e, às vezes, máquinas que não passam pelo proxy de jeito nenhum ("o sistema do fornecedor não funciona com proxy").

> Pergunte qual é essa lista. Ela é exatamente onde o seu proxy é cego.

2.5.9 VPN e ZTNA

Pergunta	Resposta
O que é?	Formas de acesso remoto. A **VPN** de acesso remoto coloca o dispositivo do usuário "dentro" da rede por um túnel cifrado. O **ZTNA** (Zero Trust Network Access) dá acesso só a aplicações específicas, verificando identidade e dispositivo a cada acesso. Detalhes de VPN no Módulo 1, seção 1.17.
Como funciona?	VPN: o usuário autentica (idealmente com MFA) num concentrador (muitas vezes o próprio NGFW) e recebe um IP de um pool interno. ZTNA: um agente leva o tráfego até um serviço de segurança, que conecta o usuário à aplicação por meio de um conector, sem expor a rede.
Por que existe?	Trabalho remoto, viagens, filiais e parceiros precisam de acesso a sistemas internos.
Onde aparece?	Na borda (concentrador VPN) ou na nuvem (ZTNA/SASE).
Como vejo no SOC?	Credencial válida de VPN é a porta da frente para o atacante. É também o elo para descobrir **quem** estava por trás de um IP do pool da VPN num horário.
Que logs mostram isso?	Concentrador VPN ou console ZTNA: usuário, IP público, IP atribuído, MFA, dispositivo, duração, bytes.
O que procuro?	Logins de países ou provedores incomuns, MFA aprovado após muitas tentativas, dispositivo não gerenciado, sessões simultâneas de locais diferentes, volume de saída alto.
O que pode ser benigno?	Viagem a trabalho confirmada, troca de operadora, plantonista de madrugada.
O que pode ser suspeito?	Login após password spraying; IP de VPS, hosting ou Tor; MFA fatigue; acesso a servidores fora do perfil do usuário.
Próximo passo	Histórico do usuário, enriquecimento do IP, atividade do IP atribuído na rede, contato com o usuário por canal alternativo.
Quando escalo?	Sinais combinados de comprometimento de conta. Contenção (derrubar sessão, desabilitar conta) só conforme Playbook e autorização.

2.5.10 WAF (Web Application Firewall)

Pergunta	Resposta
O que é?	Firewall especializado em **HTTP/HTTPS** que protege aplicações web publicadas. Pode ser um equipamento, um módulo do reverse proxy ou um serviço de nuvem/CDN.
Como funciona?	Fica na frente da aplicação, normalmente terminando o TLS. Analisa cada requisição (URL, parâmetros, cabeçalhos, corpo) contra regras: assinaturas de ataque (como o OWASP Core Rule Set), regras específicas da aplicação, limites de taxa e reputação. Opera em **modo detecção** (só registra) ou **modo prevenção** (bloqueia).
Por que existe?	O firewall de rede enxerga IP e porta 443; ele não sabe distinguir `?id=10` de `?id=10 OR 1=1`. O WAF sabe.
Onde aparece?	Na DMZ ou na nuvem, antes do load balancer e da aplicação.
Como vejo no SOC?	Gera alertas de SQL Injection, XSS, traversal, scanners e bots contra as aplicações publicadas. A pergunta central é sempre: **foi só tentativa ou chegou na aplicação?**

Pergunta	Resposta
Que logs mostram isso?	Requisição (método, URL, parâmetros, user-agent, IP do cliente), regra disparada, ação (bloqueado/registrado), código de resposta.
O que procuro?	Ação (bloqueado ou só registrado), volume e variedade de payloads da mesma origem, alvo (qual URL e parâmetro), código de resposta quando a requisição passou.
O que pode ser benigno?	Scanners de vulnerabilidade autorizados; formulários legítimos com conteúdo que parece ataque (um campo de texto com aspas e a palavra "select"); integrações de parceiros.
O que pode ser suspeito?	Payloads variados e sequenciais da mesma origem; requisições que passaram (modo detecção) com resposta 200 e tamanho anormal; erro 500 em sequência após payloads de SQLi.
Próximo passo	Verificar a ação do WAF; se passou, buscar nos logs do servidor web e da aplicação a mesma requisição e a resposta; verificar o EDR do servidor de aplicação.
Quando escalo?	Requisição maliciosa que **passou** e obteve resposta de sucesso, sinais de execução no servidor de aplicação, ou ataque contínuo a aplicação crítica.

```
# WAF (formato genérico, inspirado em WAFs de nuvem e no OWASP CRS)
{"timestamp":"2026-10-16T13:02:11-
03:00","client_ip":"203.0.113.150","host":"portal.empresa.example",
 "method":"GET","uri":"/produtos.aspx?id=10%27%20OR%20%271%27=%271","user_agent":"sqlmap/1.8",
 "rule_id":"942100","rule_msg":"SQL Injection Attack Detected via
libinjection","action":"BLOCK","status":403}

# Mesmo ataque com o WAF em modo detecção (só registra)
{"timestamp":"2026-10-16T13:02:12-
03:00","client_ip":"203.0.113.150","uri":"/produtos.aspx?id=10%20UNION%20SELECT...",
 "rule_id":"942100","action":"LOG","status":200,"bytes_sent":184211}
```

O QUE UM N1 REALMENTE PRECISA SABER

Status 403 com `action=BLOCK`: o WAF barrou. Ainda vale ver se outras variações passaram.

Status 200 com `action=LOG` e resposta de 184 KB para uma página que normalmente tem 12 KB: a requisição **chegou** na aplicação e voltou com muito mais dados do que deveria. Isso não é "alerta de WAF", isso é possível vazamento de banco.

Pergunte sempre: **o WAF está em modo bloqueio ou só detecção?** A resposta muda completamente a análise.

NA VIDA REAL

WAF instalado em 2019 em modo detecção "para não quebrar a aplicação durante a homologação".

Homologação concluída em 2019.

Modo: detecção.

Ano: você sabe qual é.

2.5.11 Load balancer

Pergunta	Resposta
O que é?	Equipamento ou serviço que distribui as requisições entre vários servidores que oferecem o mesmo serviço.
Como funciona?	Publica um **endereço virtual (VIP)** e encaminha cada conexão para um servidor do pool, conforme um algoritmo (round robin, menos conexões). Faz **health checks** periódicos e tira do pool servidores que não respondem. Pode atuar na camada 4 (TCP) ou 7 (HTTP), terminar TLS e manter a sessão do usuário no mesmo servidor (sticky session). Frequentemente faz **SNAT**: o servidor vê o IP do load balancer, não o do cliente.
Por que existe?	Disponibilidade (um servidor cai, os outros continuam) e escala (mais servidores, mais capacidade).
Onde aparece?	Na DMZ ou na zona de aplicações, entre WAF e servidores; também dentro da nuvem (balanceadores gerenciados).
Como vejo no SOC?	Principalmente como **fonte de confusão**: o IP do load balancer aparece nos logs da aplicação como se fosse a origem. E os health checks geram milhares de requisições repetidas do mesmo IP.
Que logs mostram isso?	Acesso (cliente, VIP, servidor escolhido, tempos, status), mudanças de estado dos servidores (up/down), cabeçalho X-Forwarded-For inserido.
O que procuro?	O IP real do cliente (X-Forwarded-For), qual servidor atendeu a requisição suspeita, servidores caindo do pool durante um incidente.
O que pode ser benigno?	Health checks (sempre os mesmos caminhos, como `/health` ou `/status`, em intervalo fixo), redistribuição por manutenção.
O que pode ser suspeito?	Requisições com X-Forwarded-For forjado pelo cliente (para enganar logs ou listas de bloqueio); servidores do pool caindo em sequência após requisições específicas.
Próximo passo	Recuperar o IP real e o servidor de destino, e seguir a investigação no servidor certo.
Quando escalo?	Quando a investigação da aplicação aponta comprometimento; o load balancer em si raramente é o objeto do escalonamento.

```
# HAProxy (formato HTTP, simplificado)
Oct 16 13:02:11 lb01 haproxy[2211]: 10.50.0.12:41022 [16/Oct/2026:13:02:11.512] fe_https~
be_portal/app02
  0/0/1/38/39 200 18211 - - ---- 312/298/4/2/0 0/0 {203.0.113.150} "GET /produtos.aspx?id=10
HTTP/1.1"
#  10.50.0.12 = WAF   app02 = servidor que atendeu   {203.0.113.150} = X-Forwarded-For
(cliente real)

# Log do IIS no app02 (o que a aplicação "vê")
2026-10-16 16:02:11 10.20.0.31 GET /produtos.aspx id=10 443 - 10.50.0.30 Mozilla/5.0 - 200 0 0
38
#  10.50.0.30 = IP do load balancer. O cliente real não aparece aqui, a menos que o IIS
registre o X-Forwarded-For.
#  Repare também: o IIS registra em UTC por padrão (16:02 UTC = 13:02 em Brasília).
```

MOMENTO SOC

Alerta: "IP 10.50.0.30 realizando ataque de SQL Injection contra o portal."

Analista novo: abre ticket pedindo para isolar o host 10.50.0.30.

> Infra: "Esse é o load balancer. Se isolar, o portal sai do ar para todos os clientes."
>
> O atacante agradece a ajuda. Antes de bloquear um IP interno, descubra **que tipo de ativo** ele é.

2.5.12 Gateway de e-mail

Pergunta	Resposta
O que é?	Sistema que recebe, filtra e entrega os e-mails da empresa. Pode ser local, em nuvem, ou a própria proteção nativa do provedor (como a do Exchange Online).
Como funciona?	O registro **MX** do domínio aponta para o gateway. Ele verifica reputação do remetente, SPF, DKIM e DMARC, analisa links e anexos (às vezes em sandbox), aplica políticas e entrega, coloca em quarentena ou rejeita. Detalhes no Módulo 9.
Por que existe?	E-mail continua sendo o vetor de entrada mais comum: phishing, malware, fraude de pagamento.
Onde aparece?	Na DMZ ou na nuvem, entre a internet e as caixas de correio.
Como vejo no SOC?	Origem de muitos alertas (phishing reportado, anexo malicioso, link suspeito) e fonte para responder: **quem mais recebeu essa mensagem?**
Que logs mostram isso?	Rastreamento de mensagens (remetente, destinatários, assunto, IP de origem, resultado SPF/DKIM/DMARC, veredito, ação), cliques em links reescritos, logs de quarentena.
O que procuro?	Todos os destinatários da mesma campanha, quem clicou, se algum anexo foi entregue, se a mensagem veio de domínio parecido com o da empresa.
O que pode ser benigno?	Newsletters legítimas classificadas como spam, e-mails de fornecedores com SPF mal configurado.
O que pode ser suspeito?	Remetente parecido com fornecedor real pedindo troca de dados bancários; anexos com macros ou HTML; links para domínios recém-criados.
Próximo passo	Buscar a campanha completa, verificar cliques e downloads no proxy/EDR, aplicar o Playbook de phishing.
Quando escalo?	Clique com entrada de credenciais, execução de anexo, ou campanha direcionada a executivos e financeiro.

2.5.13 IDS, IPS e NDR

Pergunta	Resposta
O que é?	**IDS** (Intrusion Detection System) detecta padrões de ataque no tráfego e alerta. **IPS** (Intrusion Prevention System) fica no caminho e também bloqueia. **NDR** (Network Detection and Response) analisa o comportamento do tráfego com mais contexto e investigação.
Como funciona?	Um sensor recebe uma cópia do tráfego (por **SPAN**, espelhamento de porta no switch, ou por **TAP**, derivação física) ou fica em linha. Compara com assinaturas (Suricata, Snort) e/ou gera metadados (Zeek) e modelos de comportamento.
Por que existe?	Para enxergar o que passa na rede, inclusive tráfego **leste-oeste** que não cruza o firewall, e para ter detecção independente dos endpoints (útil onde não há EDR).
Onde aparece?	Na borda, entre zonas e, idealmente, nos segmentos internos críticos. Muitos NGFWs têm IPS embutido.

Pergunta	Resposta
Como vejo no SOC?	Alertas de assinatura (exploit, varredura, C2 conhecido), metadados de conexões e protocolos para investigação.
Que logs mostram isso?	Alertas com assinatura e severidade, conn/dns/http/ssl logs (Zeek), fluxos.
O que procuro?	Assinatura, origem e destino, se houve resposta do alvo, repetição, correlação com EDR.
O que pode ser benigno?	Scanners autorizados, tráfego de ferramentas de TI parecido com ataque, assinaturas genéricas antigas.
O que pode ser suspeito?	Exploit com resposta do alvo, C2 conhecido, varredura interna a partir de estação.
Próximo passo	Validar se o ataque funcionou (resposta, conexão posterior, EDR no alvo).
Quando escalo?	Alerta de exploit ou C2 com evidência de sucesso.

> **DICA**
>
> Um sensor de rede só vê o que passa por ele. Se o SPAN foi configurado na porta errada, ou o tráfego cresceu e o sensor descarta pacotes, ele continua "verde" no painel e cego na prática.
>
> Pergunte: **o que exatamente esse sensor monitora** e **qual a taxa de descarte**?

2.5.14 EDR

Pergunta	Resposta
O que é?	Endpoint Detection and Response: agente instalado em estações e servidores que registra o que acontece no sistema (processos, linhas de comando, arquivos, registro, conexões) e detecta e responde a comportamentos maliciosos. Detalhes no Módulo 7.
Como funciona?	O agente coleta telemetria local, aplica detecções e envia eventos a um console central (geralmente em nuvem). O console permite investigar a árvore de processos e executar ações: isolar o host, encerrar processo, colocar arquivo em quarentena.
Por que existe?	Porque o ataque acontece no endpoint. A rede diz "o host falou com X"; o EDR diz "o Word abriu o PowerShell que baixou o arquivo que falou com X".
Onde aparece?	Em cada estação e servidor **onde estiver instalado e funcionando**.
Como vejo no SOC?	Uma das principais fontes de alerta e a principal ferramenta de investigação do endpoint e de contenção.
Que logs mostram isso?	Processo e processo pai, linha de comando, hash, usuário, arquivos criados, conexões de rede, alterações de registro, alertas e ações de resposta.
O que procuro?	Cobertura (o host tem agente? está online? quando foi o último contato?), árvore de processos, o que aconteceu antes e depois do alerta.
O que pode ser benigno?	Ferramentas administrativas, scripts de TI, instaladores, softwares de acesso remoto aprovados.
O que pode ser suspeito?	Office gerando PowerShell, binários executando de pastas temporárias, desativação do próprio agente, sensor que fica offline logo após um alerta.
Próximo passo	Investigar a árvore de processos e a linha do tempo do host; buscar o mesmo hash ou comportamento em outros hosts.

Pergunta	Resposta
Quando escalo?	Execução maliciosa confirmada, tentativa de desativar o EDR, sinais de credenciais roubadas. Isolamento só conforme Playbook e autorização.

MOMENTO SOC

Console do EDR: "Cobertura: 98%."

CMDB: 420 hosts. EDR: 391. Conta: 93%.

Descobre-se que os 98% são "dos hosts que o EDR conhece".

Os outros 7% são, por coincidência estatística impressionante, os servidores legados, o ERP e a máquina do diretor "que não pode ficar lenta".

2.5.15 SIEM

Pergunta	Resposta
O que é?	Security Information and Event Management: a plataforma que recebe logs de muitas fontes, normaliza, armazena, correlaciona, gera alertas e permite consultas. Detalhes no Módulo 6.
Como funciona?	Coleta por agentes, syslog ou APIs; processa (parsing, normalização, enriquecimento); armazena por um período de retenção; executa regras de detecção; envia alertas para a fila do SOC e para ferramentas de ticket e SOAR.
Por que existe?	Para ter um lugar único onde investigar e correlacionar eventos de fontes diferentes, e para detectar padrões que nenhuma fonte isolada perceberia.
Onde aparece?	Na zona de segurança, em data center ou nuvem.
Como vejo no SOC?	É a sua principal ferramenta de consulta e a origem de boa parte da fila. Mas ele só sabe o que recebe.
Que logs mostram isso?	Todos os que forem integrados, mais os logs de saúde do próprio SIEM (ingestão, atraso, erros de parsing).
O que procuro?	Além dos eventos: **saúde das fontes** (quais pararam de enviar, quais estão atrasadas, quais estão com campos vazios).
O que pode ser benigno?	Variações de volume por horário e dia da semana; picos em janelas de backup.
O que pode ser suspeito?	Uma fonte importante parando de enviar logs logo antes ou durante um incidente (falha ou sabotagem).
Próximo passo	Executar o Runbook de saúde de fonte (Módulo 16), abrir chamado para o responsável, registrar no handover.
Quando escalo?	Perda de visibilidade de fonte crítica (firewall de borda, DCs, EDR) por tempo relevante, ou suspeita de que a perda é intencional.

2.5.16 Nuvem e SaaS

Pergunta	Resposta
O que é?	Serviços que a empresa usa sem que estejam no seu data center: identidade (Entra ID, Okta), e-mail e colaboração (Microsoft 365, Google Workspace), aplicações SaaS e infraestrutura em nuvem (Azure, AWS, GCP).
Como funciona?	O usuário acessa pela internet, autenticando num **provedor de identidade (IdP)** com MFA e políticas de acesso condicional. Muitas empresas sincronizam o AD local com o IdP de nuvem (identidade híbrida).
Por que existe?	Escala, disponibilidade, trabalho remoto e custo. Também porque ninguém quer mais administrar servidor de e-mail.
Onde aparece?	Fora da rede da empresa. O tráfego de um usuário em casa para o M365 pode nunca passar por nenhum equipamento da empresa.
Como vejo no SOC?	Logins suspeitos, MFA fatigue, regras de encaminhamento de e-mail criadas por atacantes, compartilhamento externo de arquivos, alterações em aplicações e permissões.
Que logs mostram isso?	Sign-in logs do IdP (usuário, IP, aplicação, resultado, MFA, acesso condicional), audit logs, audit log unificado do M365, logs de atividade da nuvem (Azure Activity, AWS CloudTrail).
O que procuro?	Logins de locais e provedores incomuns, falhas em massa, consentimento a aplicações desconhecidas, regras de caixa de correio, downloads em massa.
O que pode ser benigno?	Viagens, VPN corporativa com saída em outro país, novos dispositivos registrados com chamado.
O que pode ser suspeito?	Login bem-sucedido após spraying; criação de regra que encaminha e-mails para fora ou move para pastas obscuras; app com permissões amplas consentido por usuário comum.
Próximo passo	Histórico de sign-in do usuário, ações após o login (auditoria), contato pelo canal definido.
Quando escalo?	Conta com sinais de comprometimento, ações maliciosas na caixa de correio ou na nuvem, ou alterações em configurações de identidade.

```
# Entra ID sign-in (campos principais)
TimeGenerated=2026-10-16T06:12:40Z UserPrincipalName=mpereira@empresa.example
IPAddress=45.142.120.33
Location=NL AppDisplayName="Office 365 Exchange Online" ClientAppUsed=Browser ResultType=0
AuthenticationRequirement=multiFactorAuthentication ConditionalAccessStatus=success
DeviceDetail.isManaged=false

# Falha típica antes do sucesso
TimeGenerated=2026-10-16T06:03:02Z UserPrincipalName=mpereira@empresa.example
IPAddress=45.142.120.33 ResultType=50126
#  50126 = usuário ou senha inválidos

# M365: regra de caixa criada logo depois (audit log unificado)
CreationTime=2026-10-16T06:14:05Z Operation=New-InboxRule UserId=mpereira@empresa.example
ClientIP=45.142.120.33
Parameters: Name=".", SubjectOrBodyContainsWords="fatura;boleto;pagamento", MoveToFolder="RSS
Feeds"
```

🎯 O QUE UM N1 REALMENTE PRECISA SABER

> Uma regra de caixa de correio com nome "." que move mensagens com "fatura" e "pagamento" para "RSS Feeds" é um clássico de comprometimento de e-mail corporativo: o atacante esconde da vítima as respostas da fraude que está aplicando.
>
> Nenhum firewall da empresa viu isso acontecer. Só os logs da nuvem.

2.5.17 Gerência: jump servers, backup e monitoramento

Pergunta	Resposta
O que é?	Os sistemas que administram os outros: **jump servers** (bastion, por onde administradores entram nos servidores), **cofre de senhas privilegiadas (PAM)**, **backup**, **monitoramento** (Zabbix, PRTG, Nagios), **scanner de vulnerabilidades** e consoles de gerência.
Como funciona?	Concentram acessos privilegiados e conexões para muitos ativos ao mesmo tempo.
Por que existe?	Administração controlada e auditável, recuperação de desastres, visibilidade de disponibilidade.
Onde aparece?	Zona de gerência.
Como vejo no SOC?	Duas faces: são **fontes clássicas de falso positivo** (o monitoramento faz ping e SNMP em tudo, o scanner varre tudo, o backup lê tudo) e são **alvos de altíssimo valor** (o servidor de backup é o primeiro alvo de um ransomware competente).
Que logs mostram isso?	Logs de sessão do jump server/PAM, logs do software de backup (jobs, exclusões, alterações de retenção), EDR nesses servidores.
O que procuro?	Acessos administrativos que **não** vieram do jump server, exclusão de backups ou alteração de retenção, contas de serviço de backup usadas interativamente.
O que pode ser benigno?	Varreduras do scanner na janela aprovada, pings do monitoramento, jobs noturnos de backup.
O que pode ser suspeito?	Backup sendo apagado, retenção reduzida a zero, console de backup acessado de estação comum, ferramenta de monitoramento executando comandos incomuns.
Próximo passo	Confirmar com o responsável (mudança aprovada?), verificar origem e conta.
Quando escalo?	Qualquer ação destrutiva sobre backups ou uso anômalo de contas e ferramentas de gerência. Em ataques de ransomware, isso costuma acontecer **antes** da criptografia.

2.6 Fluxos típicos e onde cada um é registrado

Saber o que cada componente faz é a metade do caminho. A outra metade é seguir um **fluxo** de ponta a ponta e marcar os pontos onde existe evidência. Estes são os quatro fluxos que mais aparecem em investigações.

Publicação de aplicação: Internet → Firewall → DMZ → WAF → Aplicação → Banco



Figura 2.2: Do cliente ao banco de dados: o que cada componente vê, registra e pode bloquear

```
Internet (cliente 203.0.113.150)
   ↓  HTTPS 443
NGFW de borda        → DNAT de 198.51.100.20:443 para o VIP do WAF   [log: sessão]
   ↓
DMZ: WAF / reverse proxy → termina TLS, analisa a requisição          [log: requisição +
regra]
   ↓  HTTP(S) interno, IP de origem passa a ser o do WAF
Load balancer        → escolhe app01 ou app02                          [log: acesso + backend]
   ↓  IP de origem passa a ser o do LB; cliente real em X-Forwarded-For
Aplicação (app02)    → processa                                        [log: IIS/Nginx +
aplicação + EDR]
   ↓  TCP 1433 com a conta de serviço da aplicação
Banco de dados       → executa a consulta                              [log: auditoria do
banco, se ativa]
```

> **DICA**
>
> Ao investigar um ataque a uma aplicação publicada, monte a cadeia **na ordem** e anote, para cada salto, o IP de origem que ele enxerga e o horário (com fuso: firewall em horário local, IIS em UTC é combinação comum).
>
> Se o WAF bloqueou, você termina no WAF. Se o WAF só registrou, você precisa descer até o servidor de aplicação e o banco para responder se houve impacto.

Saída do usuário: Usuário → Switch → Firewall → Internet

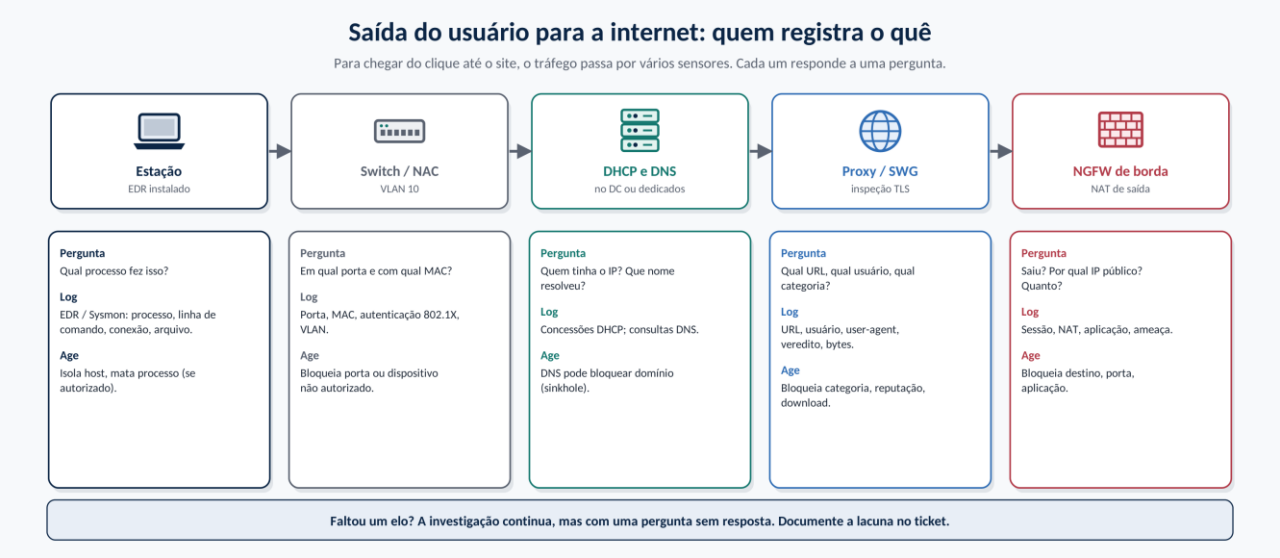


Figura 2.3: Do clique ao site: a pergunta que cada sensor responde na navegação do usuário

```
Usuário (NB-FIN-042, 10.10.0.87)          [EDR: processo, linha de comando, conexão]
   ↓
Switch de acesso (porta Gi1/0/14, VLAN 10)  [switch/NAC: porta, MAC, 802.1X]
   ↓  (DHCP já entregou o IP; DNS resolve o nome)
DNS interno                                  [DNS: consulta e resposta]
   ↓
Proxy / SWG                                  [proxy: usuário, URL, categoria, veredito]
   ↓
Firewall de borda (NAT 198.51.100.7)         [firewall: sessão, NAT, bytes]
   ↓
Internet
```

Identidade: o login que acontece em dois lugares

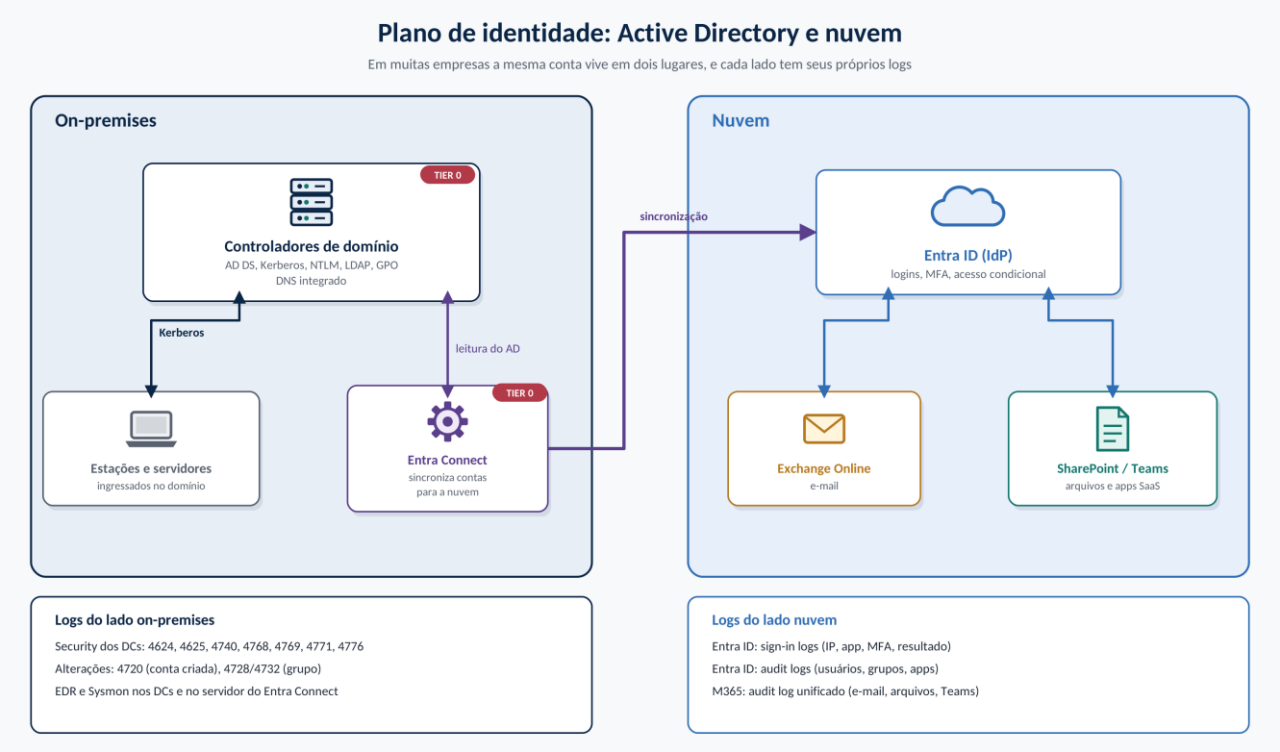


Figura 2.4: Identidade híbrida: AD on-premises sincronizado com o IdP de nuvem, cada lado com seus logs

Na maioria das empresas que usam Microsoft 365, a mesma conta existe no **AD local** e no **Entra ID**, mantida em sincronia pelo **Entra Connect**. Consequências práticas para o SOC:

- Um login no notebook dentro do escritório gera eventos nos **DCs** (Kerberos). Um login no Outlook Web de casa gera eventos **só no Entra ID**. Para ver a história completa de uma conta, você precisa das duas fontes.
- O servidor do Entra Connect e suas contas (por exemplo, a conta `MSOL_...` usada para ler o AD) são **Tier 0**: quem controla a sincronização pode afetar identidades nos dois mundos.
- Desabilitar a conta no AD local pode levar alguns minutos para refletir na nuvem (depende do ciclo de sincronização). Em contenção de conta comprometida, isso importa: os Playbooks costumam incluir revogar sessões na nuvem também.

Trabalho remoto: o perímetro foi para casa

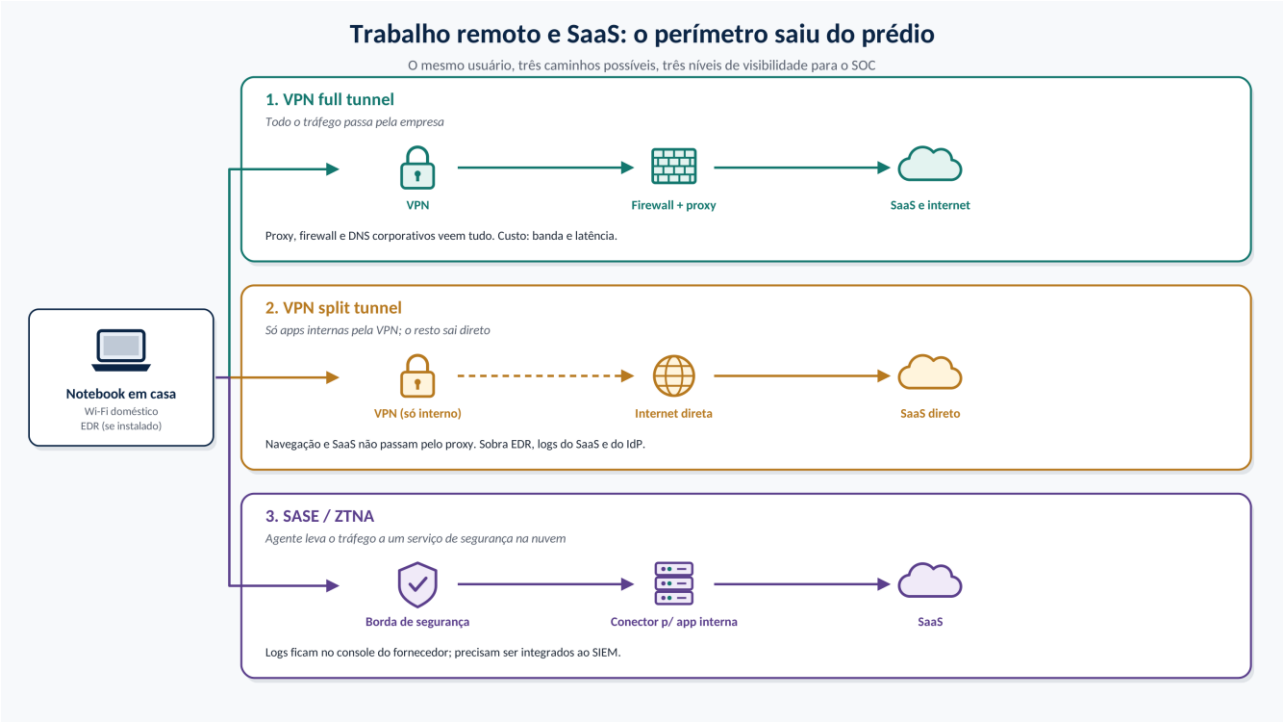


Figura 2.5: Três formas de acesso remoto e o que cada uma deixa visível para o SOC

Com trabalho remoto, a pergunta "isso passou pelo proxy?" deixou de ter resposta óbvia. Num notebook com **split tunnel**, a navegação e o acesso ao M365 saem direto pela internet de casa do usuário. Nesse cenário, a investigação depende quase toda do **EDR**, dos logs do **IdP** e do **SaaS**. Se o notebook não tiver EDR funcionando, sobra muito pouco.

> **NA VIDA REAL**
>
> Política de segurança: "Todo acesso à internet passa pelo proxy corporativo."
>
> VPN: split tunnel desde 2020, "temporariamente, por causa da pandemia".
>
> Política de segurança: ainda diz a mesma coisa.

2.7 Como os logs chegam ao SOC

Entre o evento acontecer e o alerta aparecer na sua tela existe uma cadeia de coleta. Ela tem várias etapas, e cada uma pode falhar em silêncio.

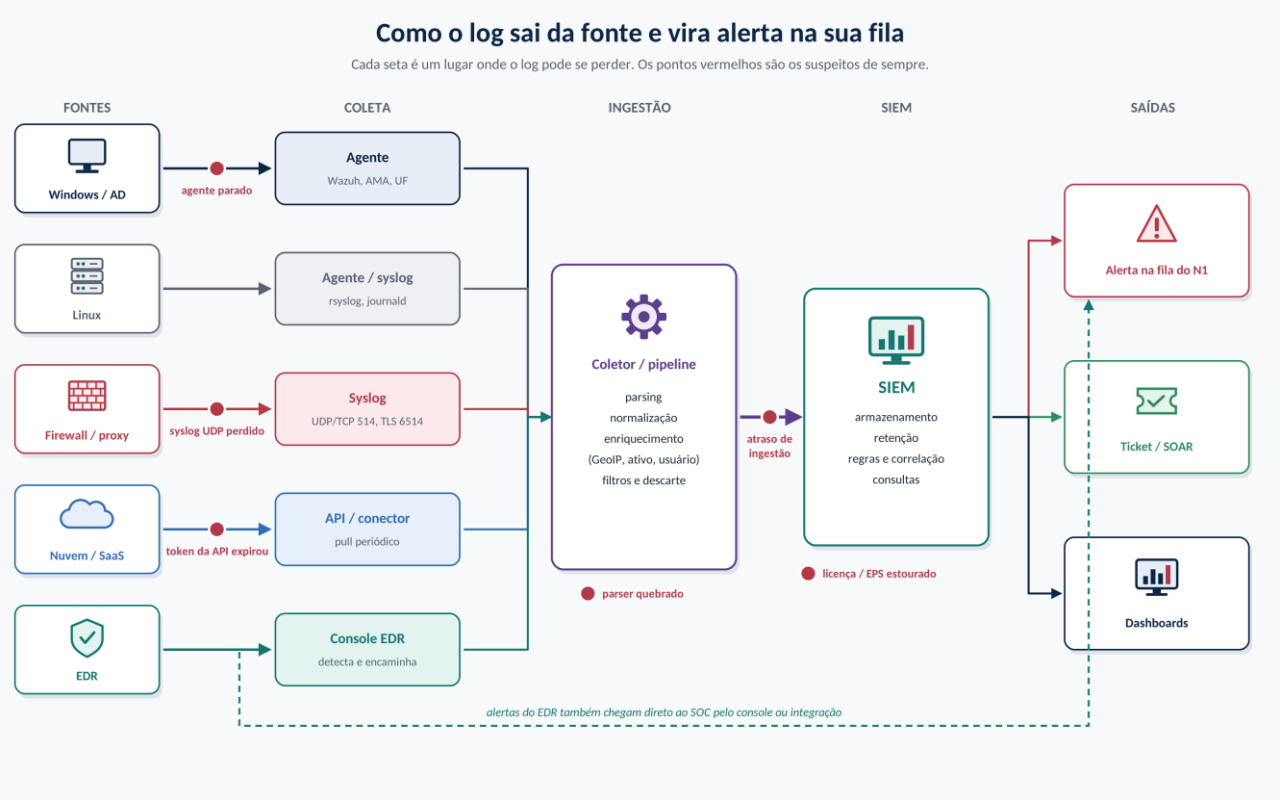


Figura 2.6: Da fonte à fila: métodos de coleta, ingestão, SIEM e os pontos de falha mais comuns

Método de coleta	Como funciona	Exemplos	Falha típica
Agente	Software instalado na fonte lê os logs locais e envia ao coletor/SIEM.	Wazuh agent, Azure Monitor Agent, Splunk Universal Forwarder, Elastic Agent.	Agente parado, desatualizado, sem permissão, máquina reinstalada sem agente.
Syslog	A fonte envia mensagens de texto pela rede a um coletor.	Firewalls, switches, proxies, appliances, Linux (rsyslog).	UDP perde mensagens sem avisar; coletor fora do ar; formato mudou após atualização e o parser quebrou.
API / conector	O SIEM (ou um conector) busca os eventos periodicamente na API do serviço.	Entra ID, M365, nuvem, EDR, SaaS.	Credencial ou token expirado, limite de requisições, permissão removida.
Encaminhamento de alertas	Ferramentas com detecção própria enviam seus alertas ao SIEM ou ao SOAR.	EDR, gateway de e-mail, WAF.	Integração desativada após troca de licença ou de console.

Ingestão, parsing e normalização (o básico)

- **Parsing:** transformar a linha de texto em campos (`src_ip`, `user`, `action`). Se o fabricante muda o formato numa atualização, o parser pode quebrar e os campos chegam vazios ou trocados.

- **Normalização:** dar o mesmo nome ao mesmo conceito vindo de fontes diferentes (`srcip`, `SourceIP` e `client` viram `src_ip`). É o que permite buscar um IP em todas as fontes de uma vez.
- **Enriquecimento:** acrescentar contexto (geolocalização do IP, criticidade do ativo, departamento do usuário).
- **Atraso de ingestão:** o tempo entre o evento acontecer e ele estar pesquisável no SIEM. Pode ser de segundos ou de horas. Uma regra que roda a cada 5 minutos procurando eventos dos últimos 5 minutos simplesmente não vê eventos que chegam com 20 minutos de atraso.
- **Retenção:** quanto tempo os logs ficam disponíveis. Determina até quando você consegue investigar para trás.

Consultas rápidas de saúde (amostra; aprofundado nos Módulos 6 e 16)

```
// Microsoft Sentinel (KQL): computadores com agente sem sinal há mais de 1 hora
Heartbeat
| summarize UltimoSinal = max(TimeGenerated) by Computer
| where UltimoSinal < ago(1h)

# Splunk (SPL): índices e sourcetypes sem eventos há mais de 60 minutos
| tstats latest(_time) as ultimo where index=* by index, sourcetype
| eval atraso_min = round((now() - ultimo) / 60)
| where atraso_min > 60

# Wazuh (no servidor): lista agentes e seu status
sudo /var/ossec/bin/agent_control -l
```

> **MOMENTO SOC**
>
> Fonte: ERP. Último evento recebido: 47 dias atrás.
>
> Dashboard do SIEM: verde.
>
> Motivo: o dashboard mede se o **coletor** está no ar, não se cada **fonte** está enviando.
>
> Você vai ouvir "o log parou ontem". Depois de investigar, vai descobrir que "na verdade parou mês passado". Monitorar a saúde das fontes é trabalho do SOC, não favor.

2.8 Matriz de visibilidade

Esta matriz resume, para cada componente, o que ele **vê**, se pode **bloquear** e se **detecta** algo por conta própria. Use-a como consulta rápida durante uma investigação ("onde eu acho a evidência disso?") e numa decisão de contenção ("quem consegue parar isso?"). Os valores são típicos; no seu ambiente dependem de licença, configuração e se o log chega ao SIEM.

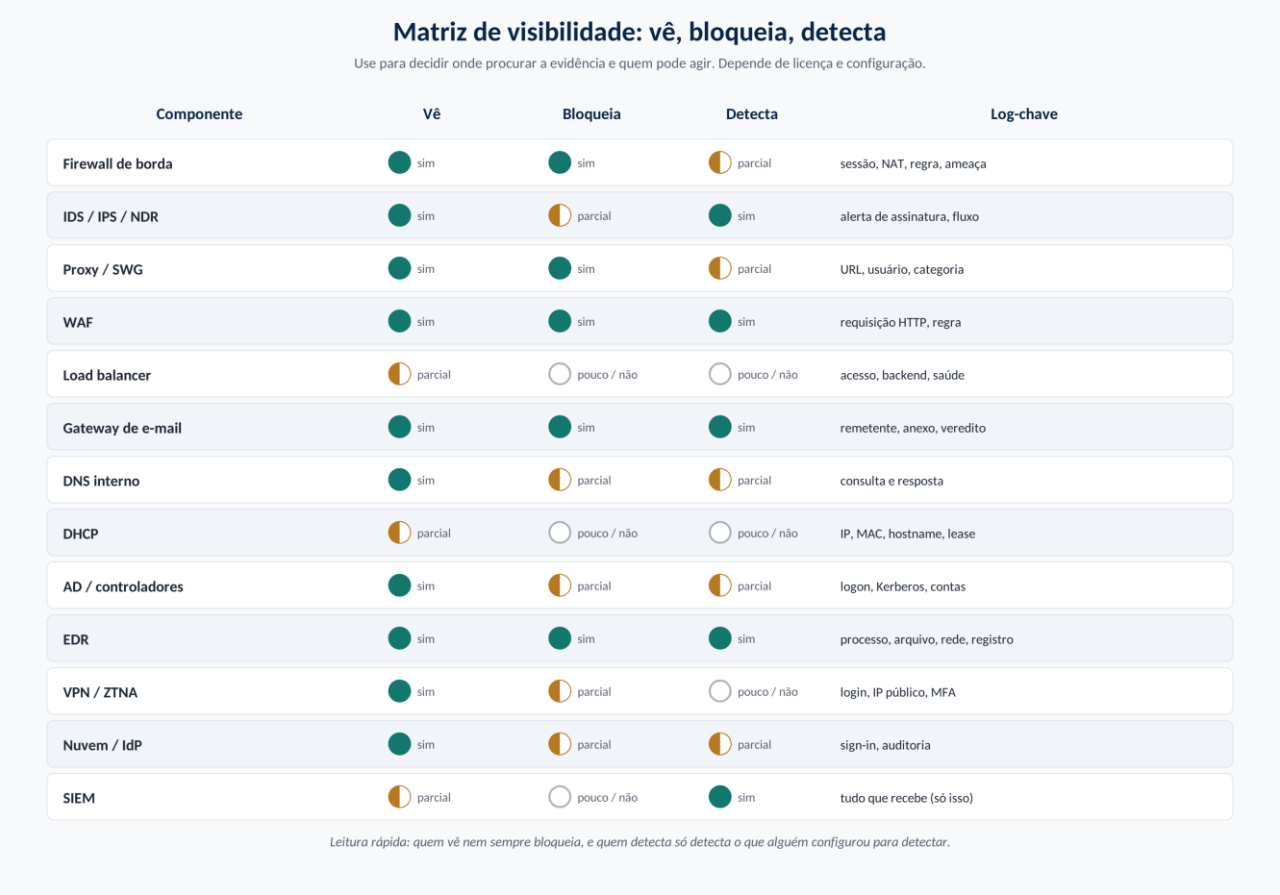


Figura 2.7: Matriz de visibilidade dos principais componentes

Para responder...	Procure primeiro em	Depois confirme em
Qual processo fez essa conexão?	EDR, Sysmon (ID 3)	Firewall/proxy para destino e volume
Qual usuário acessou essa URL?	Proxy / SWG	EDR (processo), DNS
Qual máquina tinha esse IP às 02:14?	DHCP	CMDB, EDR, AD (4624)
Qual usuário estava atrás do IP público às 14:02?	Firewall (log de NAT)	DHCP, depois logon (AD/EDR)
Quem estava no IP 10.200.1.37 (pool da VPN)?	Concentrador VPN	AD e logs internos para a atividade
O ataque à aplicação web funcionou?	WAF (ação), servidor web (status/tamanho)	Aplicação, banco, EDR do servidor
Quem mais recebeu esse e-mail?	Gateway de e-mail / rastreamento	Proxy e EDR para cliques e execução
Essa conta fez login de onde?	DCs (on-premises) e IdP (nuvem)	VPN, EDR
Essa estação falou com outras estações?	EDR das duas pontas	NDR/IDS interno, se houver

2.9 Lendo qualquer arquitetura em cinco passos

Quando receber um diagrama novo (ou quando não houver diagrama e você tiver que montar um com o time de TI), siga sempre a mesma sequência:

1. **Zonas e fronteiras:** quais zonas existem, e onde estão os firewalls ou ACLs entre elas? Onde estão os ativos Tier 0?
2. **Fluxos principais:** trace os quatro fluxos da seção 2.6 (publicação, navegação, identidade, acesso remoto) e as rotas de administração.
3. **Pontos de passagem obrigatória:** por onde todo tráfego de um tipo tem que passar? Esses são os melhores lugares para log e bloqueio.
4. **Sensores e logs:** em cada ponto, que log é gerado e **se chega ao SIEM** (com retenção suficiente)? Onde há EDR?
5. **Pontos cegos:** o que não passa por nenhum sensor? Tráfego dentro da mesma VLAN, split tunnel, servidores sem EDR, SaaS sem integração, exceções do proxy, OT/IoT.

A figura abaixo aplica esse raciocínio a um ataque completo. Repare que nenhuma etapa é vista por um sensor só, e que cada uma tem um ponto cego típico.

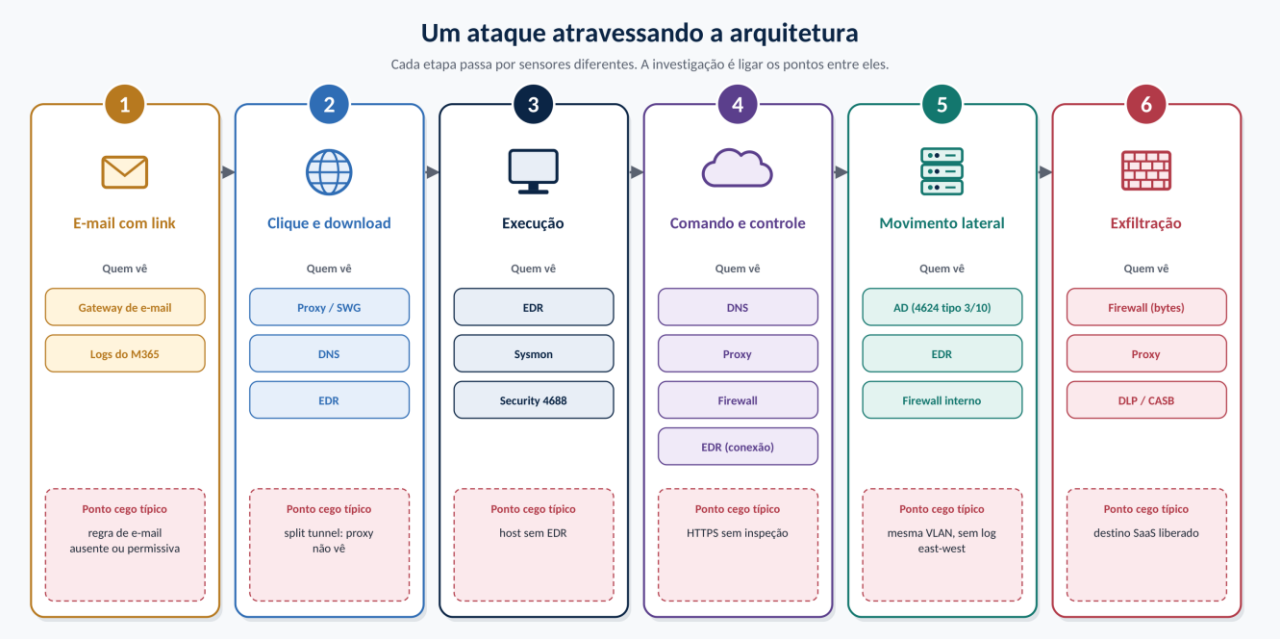


Figura 2.8: Um ataque do e-mail à exfiltração, com os sensores que veem cada etapa e seus pontos cegos

> **O QUE UM N1 REALMENTE PRECISA SABER**
>
> Este é o raciocínio que separa o operador do analista. O operador vê o alerta do EDR na etapa 3. O analista pergunta:
>
> - Como esse arquivo chegou? (etapas 1 e 2: e-mail, proxy)
> - Ele falou com alguém lá fora? (etapa 4: DNS, proxy, firewall)
> - Ele foi para outras máquinas? (etapa 5: AD, EDR de outros hosts)
> - Algo saiu? (etapa 6: volume no firewall e no proxy)
>
> O N1 não precisa responder tudo sozinho, mas precisa **fazer as perguntas e anotar no ticket o que já sabe e o que falta**.

2.10 Como isso aparece no SOC: três mini-casos

Caso 1: "SQL Injection detectado no WAF"

- **Alerta:** WAF, regra 942100, origem 203.0.113.150, alvo `portal.empresa.example/produtos.aspx`.
- **Pergunta de arquitetura:** o WAF está em modo bloqueio? O que vem depois dele?
- **Investigação:** 40 requisições bloqueadas (403) e 3 registradas sem bloqueio (200), estas com respostas muito maiores que o normal. No load balancer, as 3 foram para `app02`. No IIS do `app02`, as mesmas URLs aparecem às 16:02 UTC (13:02 local) com origem `10.50.0.30` (o load balancer).
- **Conclusão:** possível extração de dados pela aplicação. **Escalar** com a cadeia montada e recomendar verificação do banco e do EDR do `app02`.

Caso 2: "Host 10.50.0.30 atacando o portal"

- **Alerta:** regra do SIEM baseada no log do IIS detectou padrões de ataque vindos de `10.50.0.30`.
- **Pergunta de arquitetura:** que ativo é `10.50.0.30`?
- **Investigação:** CMDB e time de infraestrutura confirmam que é o VIP interno do load balancer. O cliente real está no X-Forwarded-For do log do LB (`203.0.113.150`).
- **Conclusão:** o alerta está correto quanto ao ataque, errado quanto à origem. Corrigir a origem no ticket, seguir com a investigação do Caso 1 e **recomendar que o IIS registre o X-Forwarded-For** (ajuste de log, não de regra).

Caso 3: "Servidor sem EDR com comportamento estranho"

- **Alerta:** firewall interno registra o servidor `SRV-ERP01` (Windows Server 2012 R2, sem EDR) iniciando conexões SMB para 30 estações em 2 minutos.
- **Pergunta de arquitetura:** que fontes enxergam esse servidor? Só firewall e (talvez) Security do Windows.
- **Investigação:** o Security do `SRV-ERP01` não chega ao SIEM. Nas estações de destino, o EDR mostra logons tipo 3 vindos do servidor com a conta `svc_backup`, seguidos de criação de serviço.
- **Conclusão:** comportamento de movimento lateral a partir de um ativo sem visibilidade. **Escalar imediatamente**, registrando a lacuna (servidor sem EDR e sem log no SIEM) como fator de risco.

2.11 Comandos: descobrindo a arquitetura a partir de um host

Muitas vezes a forma mais rápida de entender onde um host está "pendurado" é perguntar a ele mesmo. Use estes comandos no seu laboratório ou, no trabalho, apenas quando o procedimento permitir (via EDR com resposta remota, por exemplo).

Windows

```
ipconfig /all                      # IP, máscara, gateway, DNS, servidor DHCP, domínio DNS
route print -4                     # rotas (inclusive de VPN)
tracert -d 8.8.8.8                 # por onde o host sai para a internet
echo %LOGONSERVER%                 # DC que autenticou a sessão atual
nltest /dsgetdc:corp.local         # localizar um DC do domínio
nslookup -type=SRV _ldap._tcp.dc._msdcs.corp.local   # todos os DCs anunciados no DNS
netsh winhttp show proxy           # proxy do sistema (serviços)
reg query "HKCU\Software\Microsoft\Windows\CurrentVersion\Internet Settings" /v ProxyServer
dsregcmd /status                   # ingressado no AD, no Entra ID ou híbrido?
Get-Service -Name Sense, WinDefend  # serviços do Defender for Endpoint e do antivírus
Get-MpComputerStatus | Select AMServiceEnabled, RealTimeProtectionEnabled
w32tm /query /status               # de onde vem a hora (NTP): essencial para correlação
```

Linux

```
ip a && ip route                    # endereços e rotas
resolvectl status                   # DNS em uso (systemd-resolved); ou: cat /etc/resolv.conf
env | grep -i proxy                 # variáveis de proxy
realm list                          # ingressado em domínio AD (se usar realmd/SSSD)
timedatectl                         # fuso e sincronização de hora
systemctl status wazuh-agent        # agente de coleta rodando?
ss -tnp | grep 1514                 # conexão do agente Wazuh com o servidor
tracepath 8.8.8.8                   # caminho de saída, sem precisar de root
```

> **DICA**
>
> `w32tm` e `timedatectl` parecem fora de lugar num módulo de arquitetura. Não estão.
>
> Se o relógio do servidor está 11 minutos adiantado, a sua timeline vai colocar o efeito antes da causa. Saber qual é a fonte de hora de cada sistema faz parte de conhecer a arquitetura.

2.12 Ferramentas

Ferramenta	Para que serve	Gratuita?
diagrams.net (draw.io), Excalidraw	Desenhar arquiteturas e fluxos.	Sim
CMDB (ServiceNow, GLPI) e IPAM (NetBox)	Saber o que existe, de quem é, onde está e quão crítico é.	GLPI e NetBox, sim
Console do firewall / NGFW	Regras, objetos, zonas, logs de sessão e NAT.	Comercial
Console do EDR	Cobertura de agentes, último contato, investigação.	Comercial (Wazuh tem funções de EDR/XDR aberto)
SIEM	Consultas e painel de saúde das fontes.	Wazuh, Elastic e OpenSearch têm versões gratuitas
Zeek / Suricata	Visibilidade de rede (NDR/IDS) no laboratório.	Sim
pfSense / OPNsense	Firewall para o laboratório.	Sim

Fechamento do Módulo 2

Erros comuns

Erro	Por que é um problema	Como evitar
Achar que o SIEM vê tudo	Ele só vê o que recebe; lacunas viram falsas conclusões.	Conferir se a fonte existe, envia e está em dia antes de concluir.
Confiar no diagrama mais que nos logs	Diagramas envelhecem rápido.	Usar o diagrama como hipótese e os logs como verificação.
Tratar IP de load balancer, WAF, proxy ou NAT como atacante	Leva a bloquear um serviço inteiro.	Descobrir que ativo é o IP antes de agir; procurar X-Forwarded-For e log de NAT.
Bloquear IP de CDN ou de serviço de nuvem compartilhado	O mesmo IP serve milhares de sites legítimos.	Bloquear por domínio/URL, ou deixar a decisão para quem conhece o impacto.
Ignorar o tráfego leste-oeste	Movimento lateral passa despercebido.	Usar EDR e, onde existir, sensores internos.
Pedir isolamento de ativo crítico sem avaliar impacto	Isolar um DC, o banco do ERP ou o load balancer pode parar a empresa.	Considerar criticidade e seguir o Playbook; escalar a decisão.
Assumir que o WAF bloqueia	Muitos estão em modo detecção.	Verificar o campo de ação de cada evento.
Assumir cobertura total de EDR	Hosts sem agente são os mais arriscados.	Comparar CMDB, EDR e SIEM.
Esquecer a nuvem	Comprometimentos de e-mail e identidade acontecem fora da rede.	Incluir logs do IdP e do SaaS em toda investigação de conta.

Falsos positivos comuns ligados à arquitetura

Alerta	Causa benigna frequente	Como confirmar
Muitas requisições do mesmo IP interno à aplicação	Health checks do load balancer.	Caminho fixo (/health, /status), intervalo regular, IP do LB.
Ataque web vindo de IP interno	O IP é do WAF, do LB ou do reverse proxy.	CMDB; X-Forwarded-For.
Varredura interna	Scanner de vulnerabilidades ou monitoramento.	IP na lista de ativos autorizados; janela aprovada.
Grande volume entre servidores à noite	Backup, replicação de banco ou de arquivos.	Agenda do backup; destino é o servidor de backup.
Muitas operações no AD por uma conta de serviço	Entra Connect sincronizando, ferramenta de gestão de identidades.	Conta e servidor conhecidos (ex.: MSOL_...), padrão periódico.
Tráfego entre DCs	Replicação do AD.	Origem e destino são DCs; portas de replicação.
Mesmo evento duplicado no SIEM	Dois coletores recebendo a mesma fonte.	Campos idênticos; fonte configurada em dois destinos.
Bloqueio do WAF em uso normal	Regra genérica casando conteúdo legítimo de formulário.	Usuário autenticado, conteúdo plausível, sem variação de payloads.

Exercícios

Os exercícios 9 a 12 usam a arquitetura da Empresa Alfa, na figura abaixo. Responda antes de consultar as respostas comentadas.



Figura 2.9: Arquitetura da Empresa Alfa, usada nos exercícios

1. Uma requisição com SQL Injection sai de um cliente na internet e chega à aplicação publicada atrás de firewall, WAF e load balancer. Liste, em ordem, os pontos onde ela pode ser registrada e o que cada um registra.
2. O log do IIS mostra que o ataque veio de `10.50.0.30`. O que provavelmente é esse IP e como você descobre o cliente real?
3. Um usuário em home office, com VPN em split tunnel, baixou um arquivo malicioso de um site enquanto navegava. Que fontes de log têm chance de registrar o download? Quais certamente não registram?
4. Por que um controlador de domínio é Tier 0? Dê dois exemplos de alerta que, envolvendo um DC, devem subir de prioridade.
5. O console do EDR mostra que um servidor de arquivos não reporta há 30 dias. Quais as implicações para uma investigação hoje e o que você faz?
6. O SIEM recebe os logs de tráfego do firewall de borda, mas não os de NAT. Que tipo de pergunta você deixa de conseguir responder? (Dica: Módulo 1.)
7. Classifique cada fluxo como esperado ou suspeito e justifique: (a) servidor web da DMZ conectando ao banco interno na 1433; (b) servidor web da DMZ conectando a um DC na 445; (c) servidor web da DMZ baixando arquivo de IP desconhecido na internet.

8. Para cada componente, diga se ele vê, bloqueia e detecta um download de malware por HTTPS: proxy com inspeção TLS, firewall sem inspeção TLS, EDR, SIEM.
9. Empresa Alfa: liste pelo menos oito problemas de arquitetura, segurança ou visibilidade.
10. Empresa Alfa: uma estação sem EDR é infectada e o malware tenta se espalhar por SMB. O que você consegue investigar com as fontes disponíveis e o que fica cego?
11. Empresa Alfa: se você pudesse integrar só três novas fontes de log ao SIEM, quais seriam e por quê?
12. Explique com suas palavras por que "não encontrei nada no SIEM" não é o mesmo que "não aconteceu nada".

Laboratório

LABORATÓRIO: Lab 2.1: Mapeando a sua rede de casa

Objetivo: aplicar o método de cinco passos num ambiente real e seu.

Duração: 45 a 60 minutos.

- Com `ipconfig /all` (ou `ip a`, `ip route`, `resolvectl status`), anote IP, gateway, DNS e servidor DHCP do seu computador.
- Entre no painel do seu roteador (o endereço costuma ser o gateway) e liste os dispositivos conectados (lista de clientes DHCP).
- Descubra que logs o roteador oferece (muitos guardam só eventos do sistema; alguns, conexões e bloqueios). Anote o que ele **não** registra.
- Desenhe no diagrams.net: internet, roteador, Wi-Fi, dispositivos. Marque onde existe log e onde não existe.
- Responda às quatro perguntas para o cenário "um celular da casa começou a falar com um servidor estranho".
- Salve o desenho e as respostas em `labs/lab-2.1/` no seu repositório. Não publique IPs públicos, nomes de rede ou senhas.

LABORATÓRIO: Lab 2.2: Planejando a arquitetura do seu laboratório

Objetivo: deixar o desenho pronto para a montagem completa no Módulo 25.

- Reproduza no diagrams.net a arquitetura da Figura 2.10.
- No VirtualBox, crie uma rede **host-only** (o padrão costuma ser 192.168.56.0/24) e confira a rede **NAT** existente. Ainda não precisa instalar as VMs.
- Faça a matriz de fluxos permitidos do laboratório: quem deve falar com quem e em quais portas (por exemplo, agentes para o Wazuh na 1514).
- Liste que logs cada VM vai gerar e para onde vão.
- Calcule se o seu computador aguenta: some a RAM das VMs e deixe pelo menos 4 GB para o sistema do host.

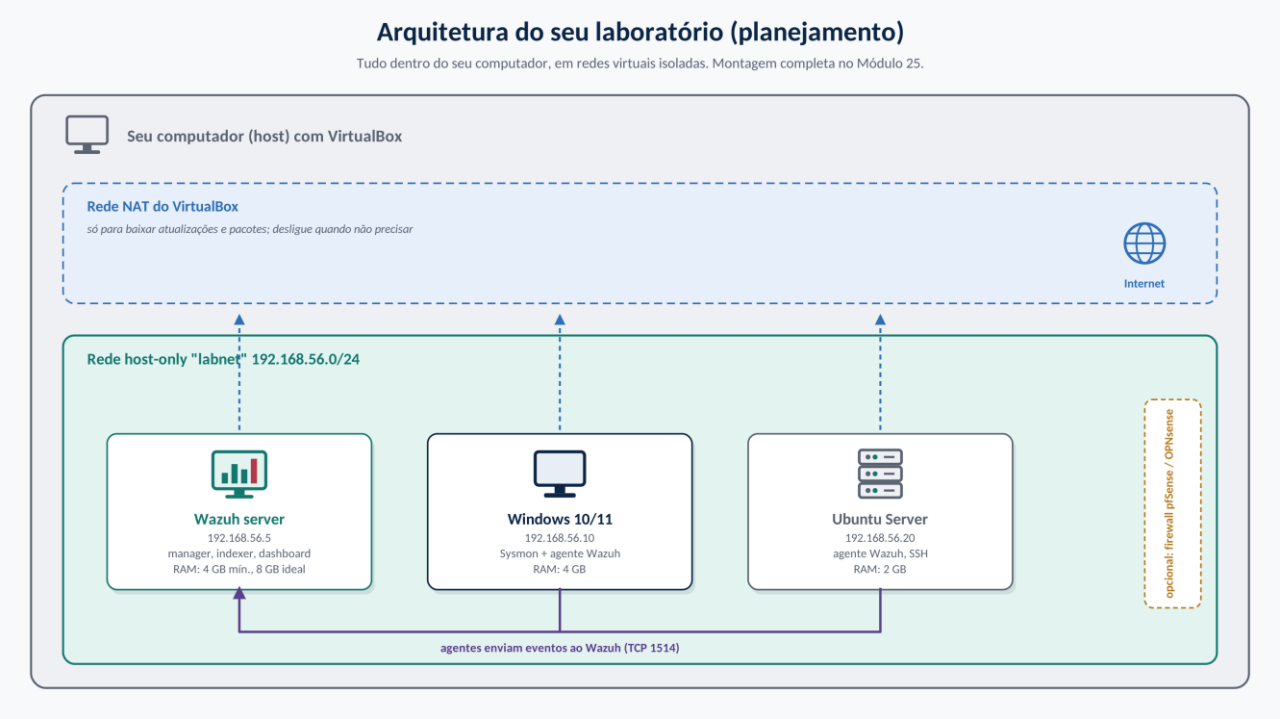


Figura 2.10: Arquitetura planejada do laboratório de estudos

LABORATÓRIO: Lab 2.3: Matriz de visibilidade da Empresa Alfa

Monte, numa planilha ou tabela, a matriz de visibilidade da Empresa Alfa **com as fontes que ela tem hoje**: para cada tipo de evento (login no DC, login na VPN, navegação, DNS, execução de processo em estação, execução em servidor, tráfego entre estações, acesso à aplicação publicada), marque se existe log, onde e se chega ao SIEM.

Depois, escreva uma recomendação de uma página para o gestor do cliente: as cinco lacunas mais graves e o que fazer primeiro. Escreva como se fosse enviar de verdade: claro, sem jargão desnecessário, sem culpar ninguém.

Perguntas de entrevista

P: Desenhe ou descreva a arquitetura de rede de uma empresa típica.

Resposta fraca	Resposta boa
"Tem o firewall e os computadores."	Internet, roteador do provedor e um NGFW de borda fazendo NAT, VPN e IPS. Atrás dele uma DMZ com WAF, reverse proxy, load balancer e gateway de e-mail. Um firewall interno segmenta usuários, servidores (com AD, DNS, DHCP, arquivos, aplicações, banco), gerência e convidados. EDR nos endpoints, SIEM recebendo logs, e cada vez mais serviços na nuvem com identidade no Entra ID. Para cada parte, eu sei onde estão os logs.

O que está sendo avaliado: Visão de conjunto e ligação com visibilidade.

P: O que é uma DMZ e por que ela existe?

Resposta fraca	Resposta boa
"É uma rede separada."	É uma zona intermediária para serviços expostos à internet. A internet só alcança a DMZ nas portas publicadas, e a DMZ só alcança o mínimo da rede interna. Se um servidor exposto for comprometido, o atacante não cai direto na rede interna. Por isso, conexões da DMZ para dentro fora do padrão são um sinal importante.

O que está sendo avaliado: Compreensão do propósito de segurança, não só da definição.

P: Qual a diferença entre firewall e WAF?

Resposta fraca	Resposta boa
"O WAF é um firewall para web."	O firewall de rede decide por IP, porta, sessão e, no caso de NGFW, aplicação e usuário. O WAF analisa o conteúdo HTTP: URL, parâmetros, cabeçalhos e corpo, para bloquear SQL Injection, XSS e outros ataques à aplicação. O firewall vê "alguém acessou a porta 443"; o WAF vê o que foi pedido. Também confiro se o WAF está em modo bloqueio ou só detecção.

O que está sendo avaliado: Camada de atuação e implicação prática.

P: O log da aplicação mostra um ataque vindo de um IP interno. O que você faz?

Resposta fraca	Resposta boa
"Isolo a máquina."	Primeiro descubro que ativo é esse IP. Se for um load balancer, WAF ou reverse proxy, a origem real está no X-Forwarded-For ou nos logs desses equipamentos. Só depois sigo a investigação com o IP correto. Isolar um load balancer derrubaria o serviço para todos.

O que está sendo avaliado: Raciocínio de arquitetura antes da ação.

P: O que é tráfego leste-oeste e por que é um ponto cego?

Resposta fraca	Resposta boa
"É tráfego interno."	É o tráfego entre sistemas dentro da empresa, ao contrário do norte-sul, que entra e sai. Quando ocorre dentro da mesma VLAN, não passa por firewall e não gera log de rede. É exatamente onde acontece o movimento lateral. A visibilidade vem do EDR nas pontas, dos logs de autenticação e de sensores internos, se existirem.

O que está sendo avaliado: Entendimento de visibilidade e de movimento lateral.

P: Qual a diferença entre EDR e SIEM?

Resposta fraca	Resposta boa
"Os dois detectam ataques."	O EDR é um agente no endpoint que registra processos, arquivos, registro e conexões, detecta comportamentos e permite resposta, como isolar o host. O SIEM centraliza logs de muitas fontes, inclusive do EDR, correlaciona e permite consultas. O EDR vê fundo um host; o SIEM vê largo o ambiente, mas só o que recebe.

O que está sendo avaliado: Papéis complementares.

P: Como você investigaria um servidor que não tem EDR?

Resposta fraca	Resposta boa
"Não dá para investigar."	Uso o que existe ao redor: logs do Windows ou Linux se chegarem ao SIEM, firewall entre zonas, logs de autenticação nos DCs, EDR das máquinas com quem ele falou, logs da aplicação e do backup. Registro a falta de EDR como lacuna e risco no ticket e, se houver indício de comprometimento, escalo cedo, porque a visibilidade é baixa.

O que está sendo avaliado: Criatividade investigativa e honestidade sobre limitações.

P: Como o trabalho remoto e o uso de SaaS mudaram a visibilidade do SOC?

Resposta fraca	Resposta boa
"Agora tudo é na nuvem."	Muito tráfego deixou de passar pelo proxy e pelo firewall da empresa, principalmente com split tunnel. A visibilidade passou a depender do EDR no notebook, dos logs do provedor de identidade e dos logs do próprio SaaS. Por isso investigações de conta precisam olhar AD e IdP, e os logs da nuvem precisam estar integrados ao SIEM.

O que está sendo avaliado: Atualização sobre o cenário real.

P: O que você pergunta para entender um ambiente novo?

Resposta fraca	Resposta boa
"Qual é o SIEM."	Quais são as zonas e onde estão os firewalls; quais os IPs públicos; onde estão os DCs e o que é Tier 0; que fontes chegam ao SIEM e com que retenção; qual a cobertura real do EDR; se o WAF está em bloqueio; se existe proxy e quais as exceções; como é o acesso remoto; quem é o owner dos ativos críticos.

O que está sendo avaliado: Método e maturidade.

P: Um alerta diz que uma fonte de log parou de enviar. É um problema de segurança?

Resposta fraca	Resposta boa
"Não, é problema de infraestrutura."	É um problema de visibilidade, que é um problema de segurança: enquanto a fonte está muda, qualquer atividade ali fica invisível. Verifico se é atraso ou parada real, sigo o Runbook de saúde, aciono o responsável, registro no handover e avalio com o Lead se há motivo para suspeitar de ação intencional.

O que está sendo avaliado: Entendimento de que perda de telemetria é risco.

Checklist de domínio

- ☐ Desenho de memória uma arquitetura corporativa típica com suas zonas.
- ☐ Explico DMZ, segmentação, matriz de fluxos permitidos e tiering.

- ☐ Para os 17 componentes deste módulo, sei o que é, por que existe e que logs gera.
- ☐ Sigo os fluxos de publicação, navegação, identidade e acesso remoto, marcando os pontos de log.
- ☐ Explico por que o IP de origem muda ao passar por WAF, load balancer, proxy e NAT, e onde achar o IP real.
- ☐ Descrevo como o log chega ao SIEM (agente, syslog, API) e onde ele costuma se perder.
- ☐ Uso a matriz de visibilidade para decidir onde procurar e quem pode bloquear.
- ☐ Aplico o método de cinco passos e encontro pontos cegos.
- ☐ Sei que comandos usar para descobrir rede, DC, proxy, ingresso em domínio, EDR e hora de um host.
- ☐ Concluí os Labs 2.1, 2.2 e 2.3 e os 12 exercícios.

Resumo do módulo

- Arquitetura, para o N1, é saber **onde o tráfego passa, que log cada ponto gera, se esse log chega ao SIEM e quem pode agir**.
- As quatro perguntas: **onde estão os logs, quem enxerga, quem bloqueia, quem detecta**.
- Zonas típicas: Internet, DMZ, usuários, servidores, gerência, convidados, OT/IoT. Entre zonas existe controle e log; dentro de uma zona, quase nunca.
- **Tier 0** (DCs, identidade) é o mais crítico; alertas ali sobem de prioridade, e ações sobre eles exigem cuidado redobrado.
- Ao passar por WAF, load balancer, proxy e NAT, **o IP de origem muda**; o IP real fica em X-Forwarded-For ou no log de tradução.
- O **WAF** pode estar só em detecção; o **EDR** pode não estar em todo lugar; o **SIEM** só vê o que recebe.
- Trabalho remoto e SaaS levaram parte do perímetro para fora: **identidade e endpoint** viraram as fontes principais.
- O log percorre fonte → coleta → ingestão → SIEM → alerta, e pode se perder em qualquer etapa. Monitorar a saúde das fontes é trabalho do SOC.
- Diagrama é hipótese; log é verificação. Ponto cego encontrado é lacuna documentada, não "nada aconteceu".

Respostas comentadas dos exercícios

Exercício 1. (1) **Firewall de borda:** registra a sessão (IP real do cliente, porta 443, regra, bytes); não vê o payload sem inspeção. (2) **WAF:** registra a requisição completa, a regra disparada e a ação. (3) **Load balancer:** registra o acesso, o servidor que atendeu e, se configurado, o X-Forwarded-For. (4) **Servidor web/aplicação:** registra URL, status e tamanho da resposta (com o IP do LB como origem) e, se houver, erros da aplicação; o EDR do servidor registra processos. (5) **Banco de dados:** registra a consulta, se a auditoria estiver ativa. Se o WAF bloqueou, a cadeia termina nele.

Exercício 2. Provavelmente é o load balancer (ou outro intermediário, como WAF ou reverse proxy). Confirme na CMDB ou com o time de infraestrutura. O cliente real está no cabeçalho **X-Forwarded-For** registrado pelo LB ou pelo WAF, ou nos logs do próprio WAF/firewall de borda no mesmo horário e URL. Lembre de alinhar os fusos (o IIS registra em UTC por padrão).

Exercício 3. Têm chance: **EDR** do notebook (processo do navegador, arquivo criado, execução, conexão), **Sysmon** se instalado, logs do **navegador**/sistema local e, se a navegação passar por um SWG em nuvem

com agente, o **SWG**. Certamente não registram: **proxy corporativo** e **firewall de borda**, porque com split tunnel a navegação sai direto pela internet de casa. O DNS corporativo também provavelmente não vê. Se o notebook não tiver EDR funcional, a visibilidade fica quase nula, e isso deve ir para o ticket.

Exercício 4. Porque o DC controla a identidade de toda a rede: quem o compromete pode criar contas, alterar grupos, emitir tickets Kerberos e acessar qualquer sistema do domínio. Exemplos de alerta que sobem de prioridade: processo suspeito executado num DC; alteração do grupo Domain Admins; logon interativo de conta incomum num DC; pedido de replicação de diretório vindo de algo que não é DC; agente do EDR parado num DC.

Exercício 5. Por 30 dias, tudo que aconteceu nesse servidor está sem telemetria de endpoint: a investigação depende de logs do Windows (se chegarem ao SIEM), firewall entre zonas, AD e EDR das máquinas que falaram com ele. Ações: registrar a lacuna no ticket, abrir chamado para o responsável pelo EDR/servidor, verificar se o agente foi removido, desativado ou se o servidor foi reinstalado, e avaliar com o Lead se a parada coincide com algum evento suspeito. Se estiver ligado a um incidente, escalar.

Exercício 6. Você deixa de conseguir **atribuir uma conexão vista de fora (IP público + porta + horário) a um host interno**. Exemplos: denúncia de abuso enviada por terceiros, alerta de inteligência de ameaças sobre seu IP público, investigação de acesso a um site malicioso relatado por parceiro. O log de tráfego pode até mostrar o IP interno, mas sem a tradução você não casa com o que o mundo externo viu.

Exercício 7. (a) **Esperado**, se for a aplicação acessando seu banco na porta definida e documentada na matriz de fluxos. (b) **Suspeito**: um servidor web da DMZ não tem motivo para SMB num DC; pode ser movimento lateral ou tentativa de acesso a credenciais. (c) **Suspeito**: servidores da DMZ só deveriam falar com a internet para destinos conhecidos (atualizações); download de IP desconhecido sugere ferramenta sendo baixada após exploração. Em (b) e (c), verificar o processo no EDR do servidor e os logs do WAF e do servidor web anteriores ao evento.

Exercício 8. Proxy com inspeção TLS: vê a URL e o arquivo, pode bloquear, detecta por reputação, categoria ou antivírus. **Firewall sem inspeção TLS:** vê IP, porta, SNI e volume; pode bloquear o destino; detecta pouco (reputação do IP ou domínio). **EDR:** vê o arquivo gravado e o que acontece quando ele é executado; pode bloquear a execução e isolar; detecta por comportamento e assinatura. **SIEM:** vê o que receber dos três; não bloqueia; detecta por correlação (por exemplo, download de domínio novo seguido de execução).

Exercício 9. Entre outros: (1) rede plana sem VLANs, permitindo que tudo fale com tudo; (2) sem DMZ: site público dentro da LAN, com port forward direto; (3) site público no mesmo servidor que acessa o banco do ERP; (4) ERP exposto à internet por RDP (porta 3389); (5) VPN sem MFA; (6) Wi-Fi de visitantes na mesma rede; (7) servidor legado Windows 2012 R2 (fora de suporte) e sem EDR; (8) 80 estações sem EDR; (9) estações usando DNS externo (8.8.8.8), sem visibilidade de DNS; (10) sem proxy; (11) SIEM sem log de NAT e com só 15 dias de retenção; (12) backup no mesmo domínio e com compartilhamento aberto, alvo fácil de ransomware; (13) conta de serviço do backup como Domain Admin; (14) ERP sem owner; (15) relógio do ERP dessincronizado.

Exercício 10. Dá para ver: no **firewall**, quase nada (o tráfego SMB fica dentro da LAN plana e não cruza o firewall); no **Security do DC**, autenticações da conta usada (4624/4625, 4768/4769/4776) se o malware usar credenciais de domínio; no **EDR das estações de destino que têm agente**, logons de rede, criação de serviços e execução. Fica cego: a estação de origem (sem EDR, sem log no SIEM), as estações de destino

sem EDR, o tráfego SMB em si, o DNS (vai para 8.8.8.8) e qualquer coisa além de 15 dias. A conclusão do ticket deve listar essas lacunas explicitamente.

Exercício 11. Uma resposta boa: (1) **cobertura de EDR completa** (ou ao menos integrar o EDR existente e instalar nas 80 estações e no ERP), porque o ataque acontece no endpoint; (2) **log de NAT do firewall** (barato, já existe no equipamento, e resolve atribuição); (3) **DNS interno**, trocando o 8.8.8.8 por um resolver corporativo com log, ou os logs do Entra ID/M365 se a empresa usar nuvem. Outras escolhas são aceitáveis se bem justificadas, por exemplo Security dos servidores críticos. O importante é justificar por **impacto na visibilidade** e **custo/facilidade**.

Exercício 12. Porque o SIEM só contém o que recebeu. O evento pode ter acontecido numa fonte que não envia logs, que estava com o agente parado, cujo parser quebrou, que chegou atrasada, que está fora da retenção ou que nunca foi integrada (SaaS, servidor sem agente, tráfego dentro da mesma VLAN). A conclusão honesta é "não encontrei evidência nas fontes X, Y e Z, no período tal; as fontes A e B não estavam disponíveis".

Próximo módulo

Módulo 3: Windows para SOC. Processos, threads, serviços, registro, tarefas agendadas, PowerShell, WMI, RDP e SMB pelo lado do sistema operacional; o Visualizador de Eventos e os logs Security, System, Application, PowerShell e Defender; os Event IDs obrigatórios (4624, 4625, 4688, 4697, 4698, 4720, 4740, 4768, 4769, 7045 e outros) com campos, cenários benignos e suspeitos; Logon Types; comandos de investigação; e uma introdução ao Sysmon.